

IAM

レクチャー	レクチャーで学ぶ内容
IAMの概要	IAMの基本的な機能や仕組みについて理解します。
IAM設計	実際に会社などの組織でIAM設計を行う場合を想定した簡単なケーススタディを実施します。
IAMグループへのポリシー適用 (ハンズオン)	IAMポリシーを作ってIAMグループに適用するハンズオンを実施します。
IAMロールへのポリシー適用 (ハンズオン)	IAMポリシーを作ってIAMロールに適用するハンズオンを実施します。
IAMロールの権限移譲	IAMロールを使って別のアカウントに対して権限を委譲するクロスアカウントのアクセス設定を実施します。

IAM

レクチャー	レクチャーで学ぶ内容
アクセス権限の境界設定	アクセス権限の境界設定による権限範囲の管理方法を学習します。
アクセスアナライザーの利用	IAMアクセスアナライザーの初期設定を実施します。
AWS Organizationsの概要	AWS Organizationsの内容と基本的な機能や役割を理解します。
AWS Organizationsの設定	AWS Organizationsを利用した複数アカウントの統合管理の設定を実施します。

IAMの概要

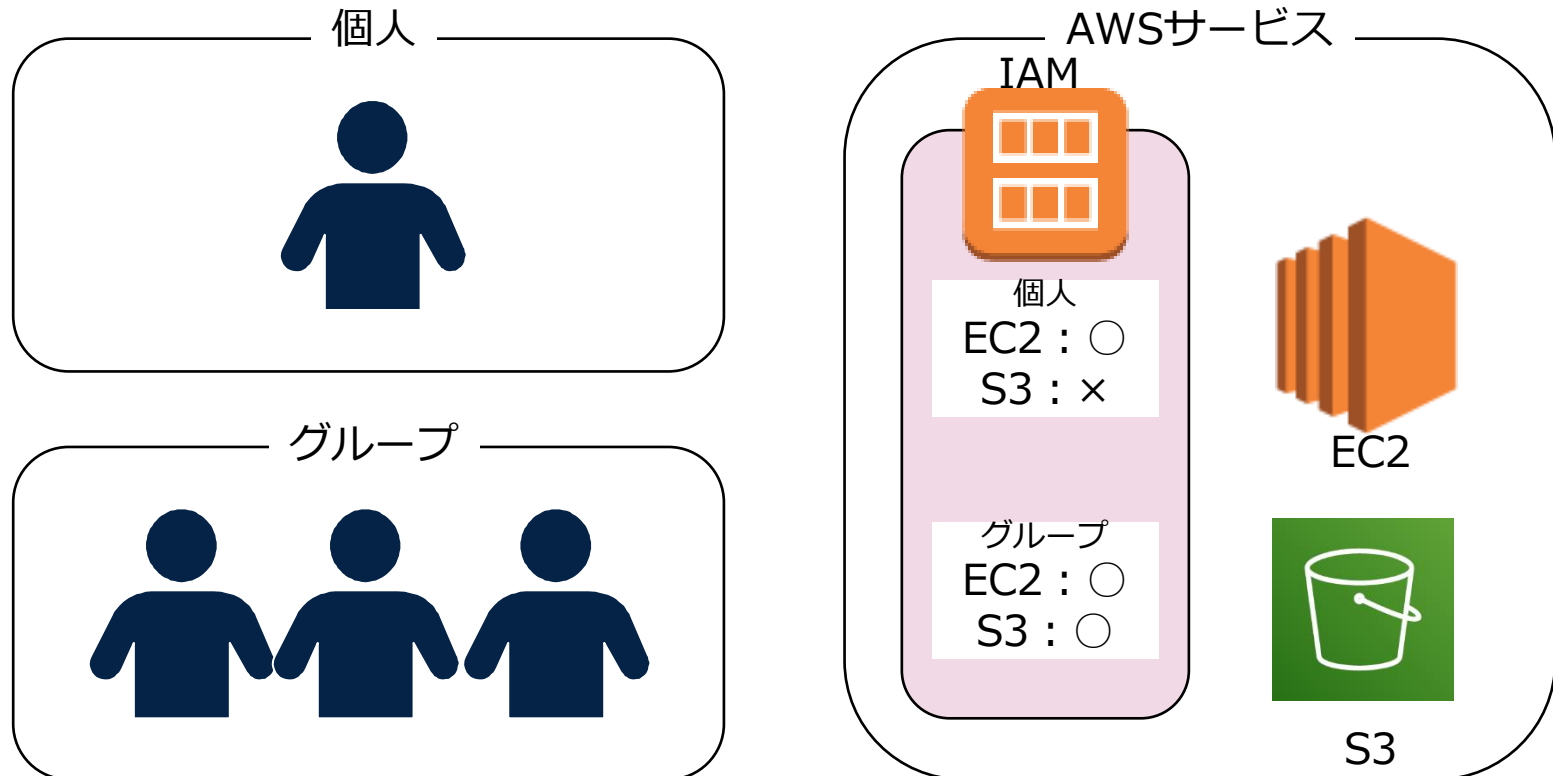
IAMとは

AWS Identity and Access Management (IAM)は安全にAWS操作を実施するための認証・認可の仕組み

- AWSアカウント内のユーザーを作成
- AWSリソースへのアクセス権限を管理
- リソース間のアクセス権限を管理
- 一時的なアクセスを許可

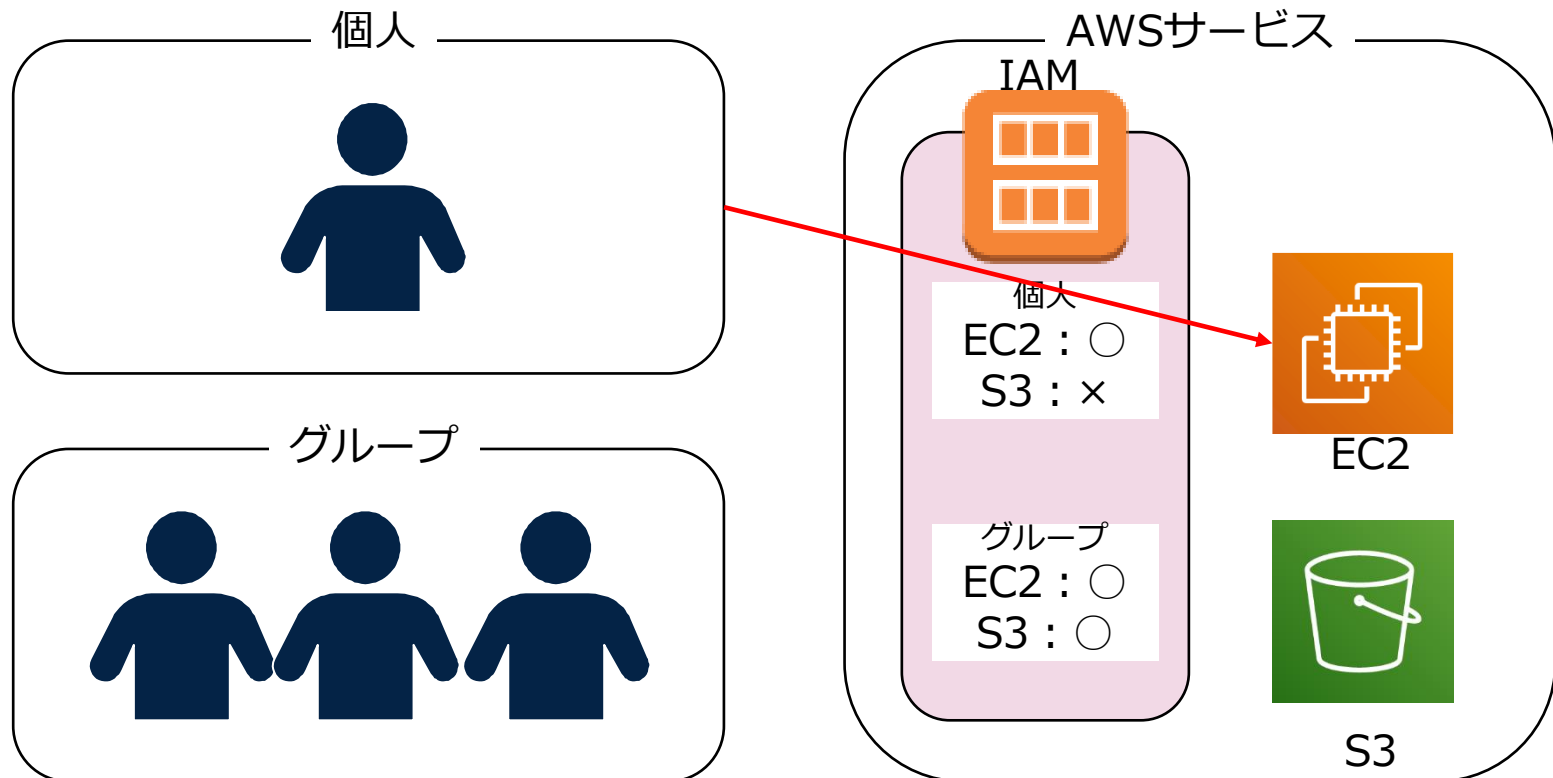
IAMとは

AWS Identity and Access Management (IAM)は安全にAWS操作を実施するための認証・認可の仕組み



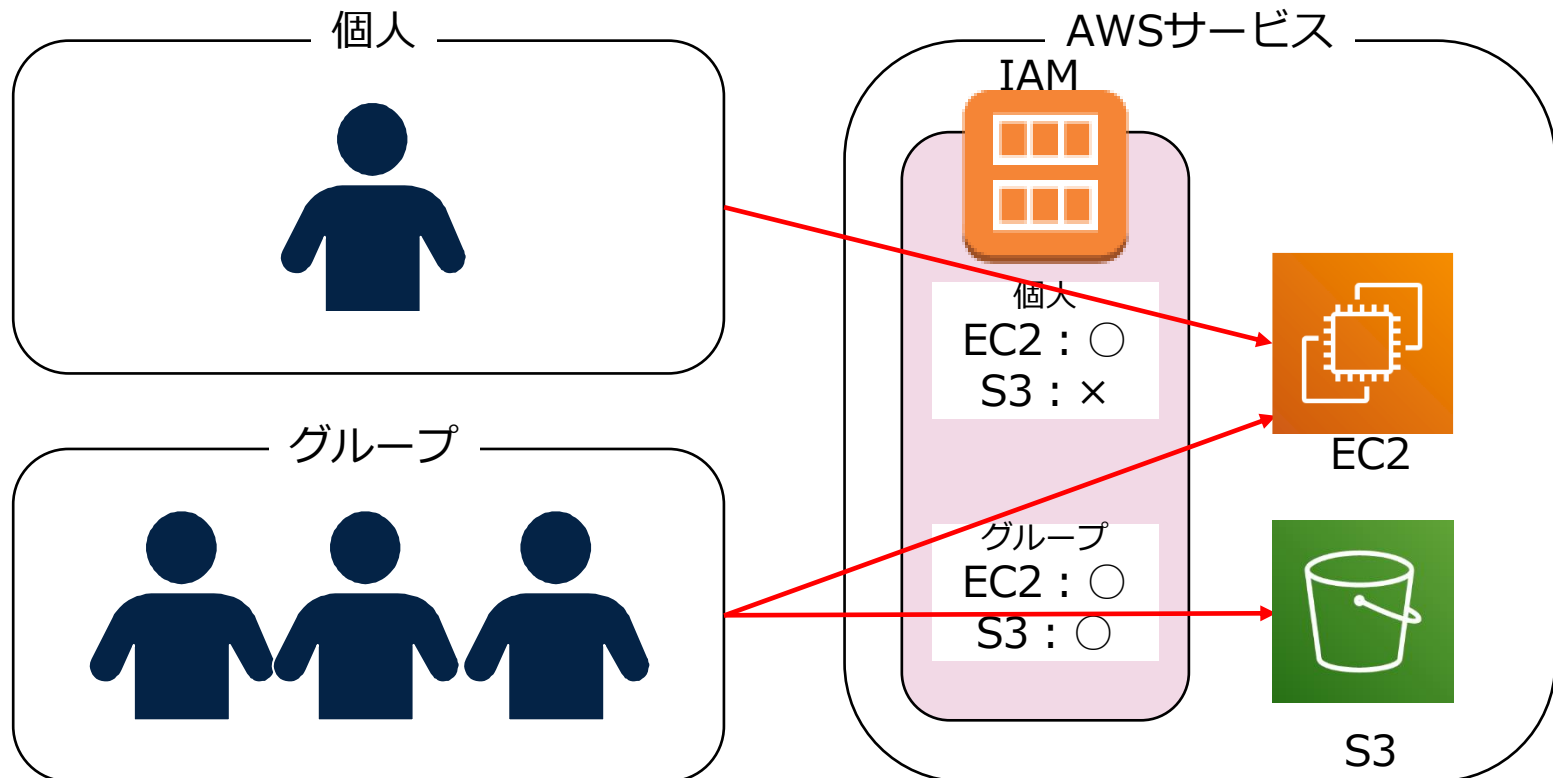
IAMとは

AWS Identity and Access Management (IAM)は安全にAWS操作を実施するための認証・認可の仕組み



IAMとは

AWS Identity and Access Management (IAM)は安全にAWS操作を実施するための認証・認可の仕組み



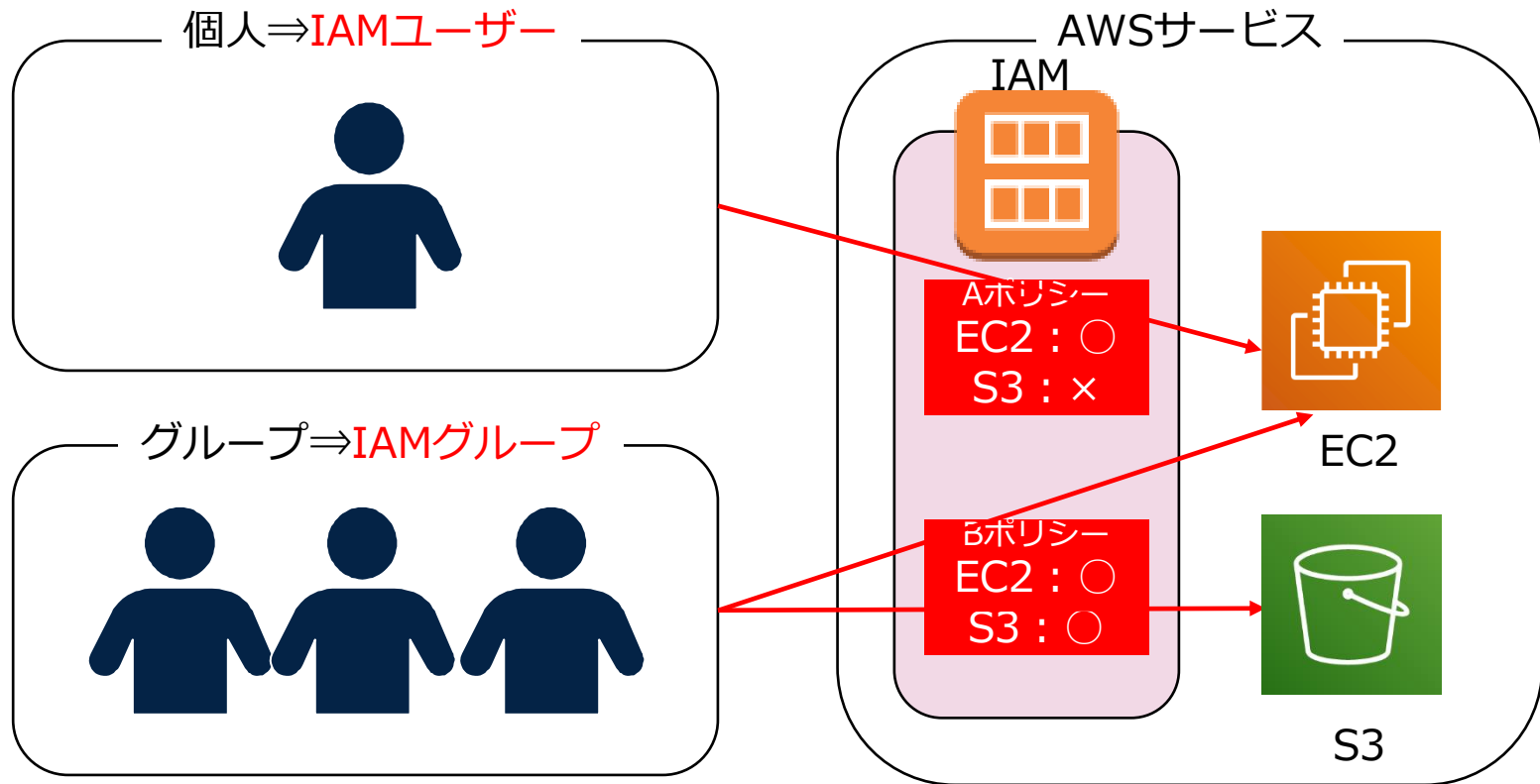
主要トピック

IAMの主要要素はユーザー、グループ、ポリシー、ロール

IAMポリシー	✓ ユーザーなどへのアクセス権限を付与するための設定ドキュメントのこと（JSON形式の文書）
IAMユーザー	✓ AWSアカウント内に追加される利用ユーザー ✓ AWS上の利用者はIAMユーザーという権限を付与されたエンティティとして設定される。
IAMユーザーグループ	✓ グループとしてまとめて権限を付与する仕組み ✓ グループには複数のIAMユーザーが設定される
IAMロール	✓ AWSリソースが別のリソースに対するアクセス権限を付与する仕組み ✓ 別のAWSアカウントのIAMユーザーにアクセス権限を委譲する際にも利用

IAMポリシー

ユーザーなどへのアクセス権限を付与するための設定ドキュメントのこと（JSON形式の文書）



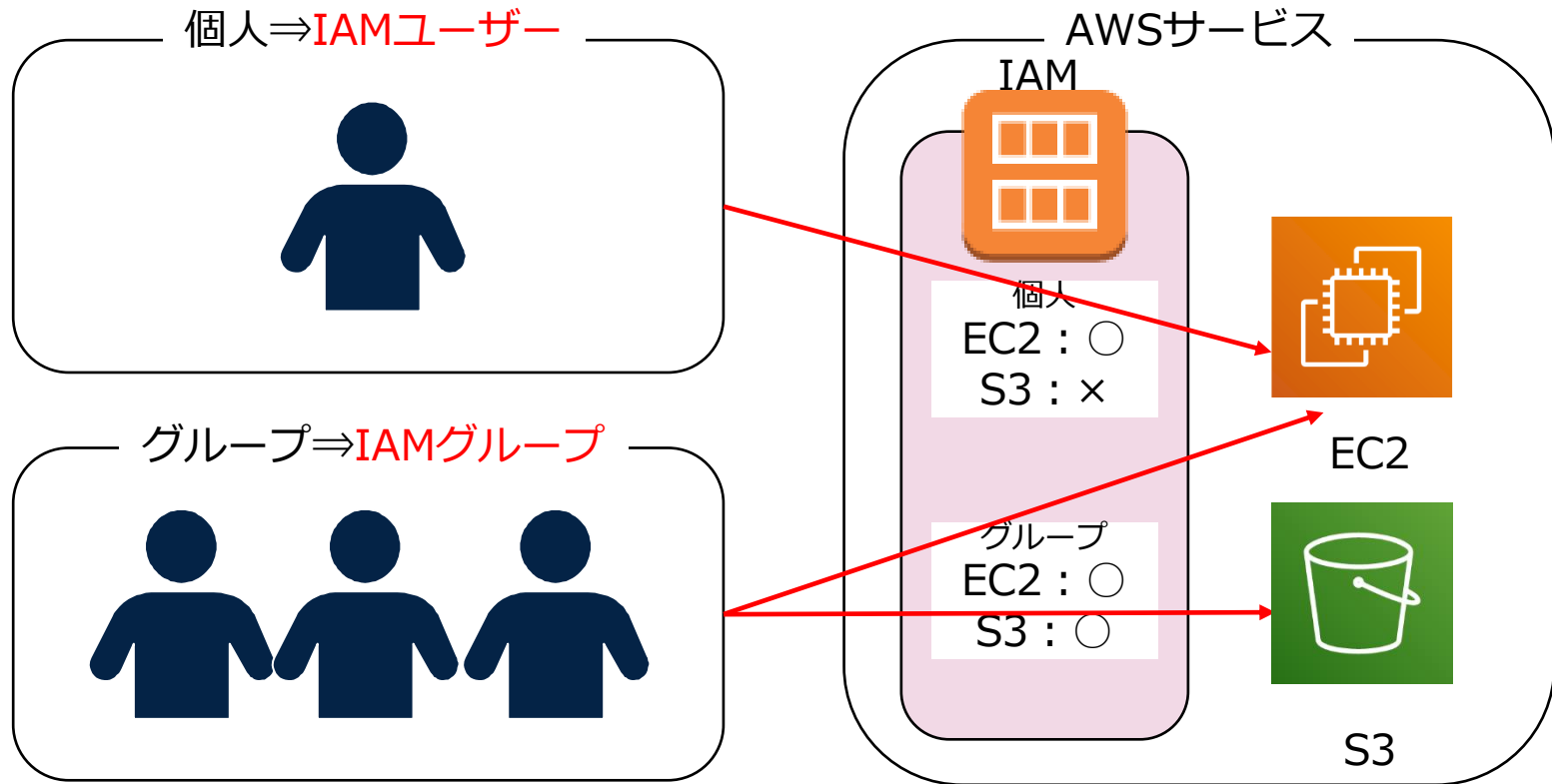
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::123456789012:root" },
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3:::test-bucket",
        "arn:aws:s3:::test2-bucket/*"
      ]
    },
    {
      "Condition": {
        "NotIpAddress": {
          "aws:SourceIp": [
            "192.0.2.0/24",
            "203.0.113.0/24"
          ]
        }
      }
    }
  ]
}
```

IAMユーザー

IAMポリシー内でAWSサービスを利用できるユーザー。基本操作はIAMユーザーで実施することになる



IAMユーザー

AWS上の利用者はIAMユーザーという権限を付与されたエンティティとして設定される。

ルートユーザー (IAMではない)	• AWSアカウント作成時に作られるIDアカウント • 全てのAWSサービスとリソースを使用できる権限を有する • 日常的なタスクはルートユーザーを使用しないことが強く推奨される
管理者権限 (IAMユーザー)	• 管理者権限の許可が付与されたIAMユーザーのこと • IAMの操作権限まであり • ルートアカウントしかできない権限は付与されない。
パワーユーザー (IAMユーザー)	• パワーユーザーはIAM以外の全てのAWSサービスにフルアクセス権限を有するIAMユーザー • IAMの操作権限なし

ルートユーザー

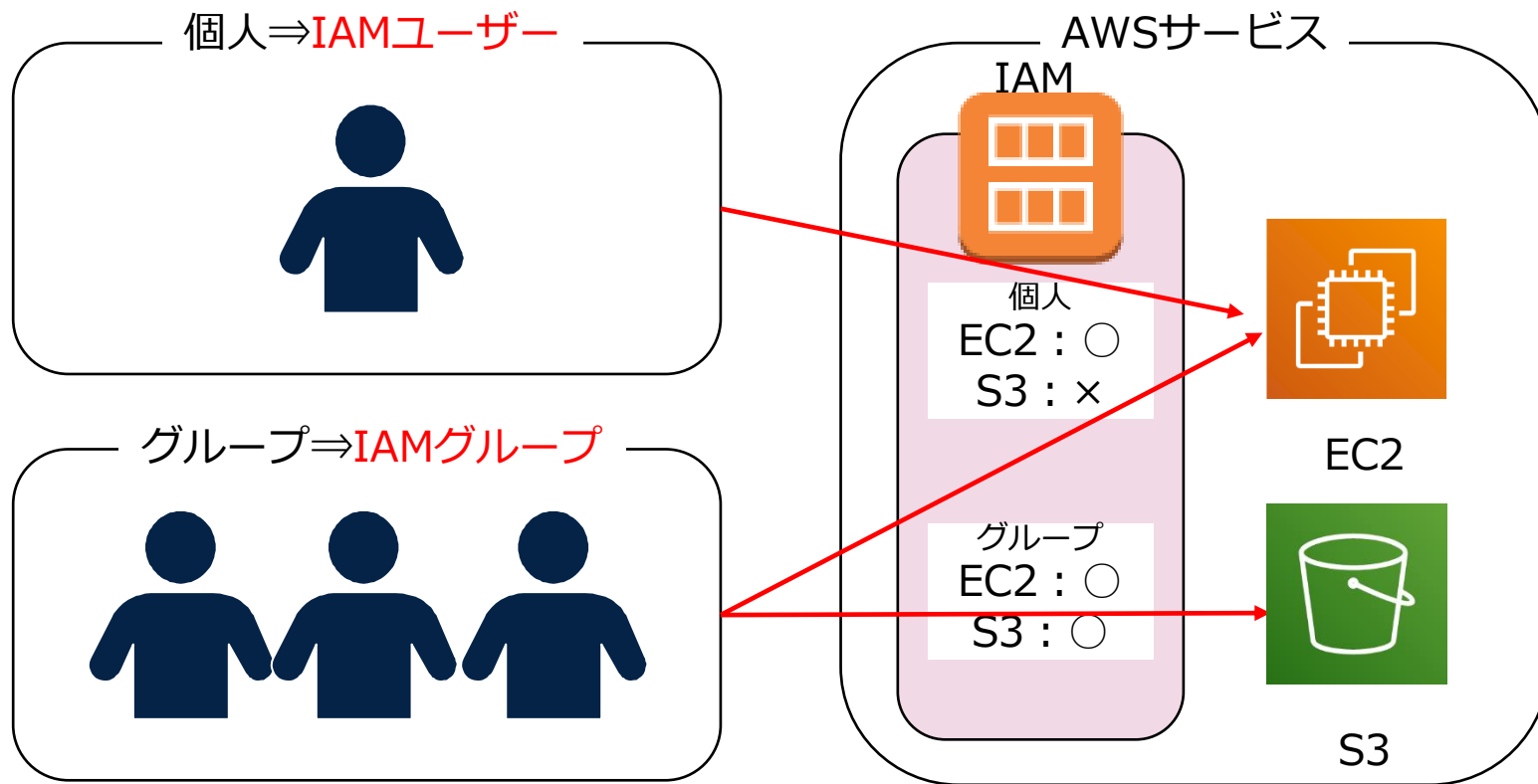
ルートユーザーは最初に登録したアカウントのことで、特別な操作権限を有する。

【ルートユーザーのみの実施権限】

- ❑ AWSルートアカウントのメールアドレスやパスワードの変更
- ❑ IAMユーザーの課金情報へのアクセスに関するactivate/deactivate
- ❑ 他のAWSアカウントへのRoute53のドメイン登録の移行
- ❑ AWSサービス（サポート等）のキャンセル
- ❑ AWSアカウントの停止
- ❑ コンソリデテッドビルディングの設定
- ❑ 脆弱性診断フォームの提出
- ❑ 逆引きDNS申請

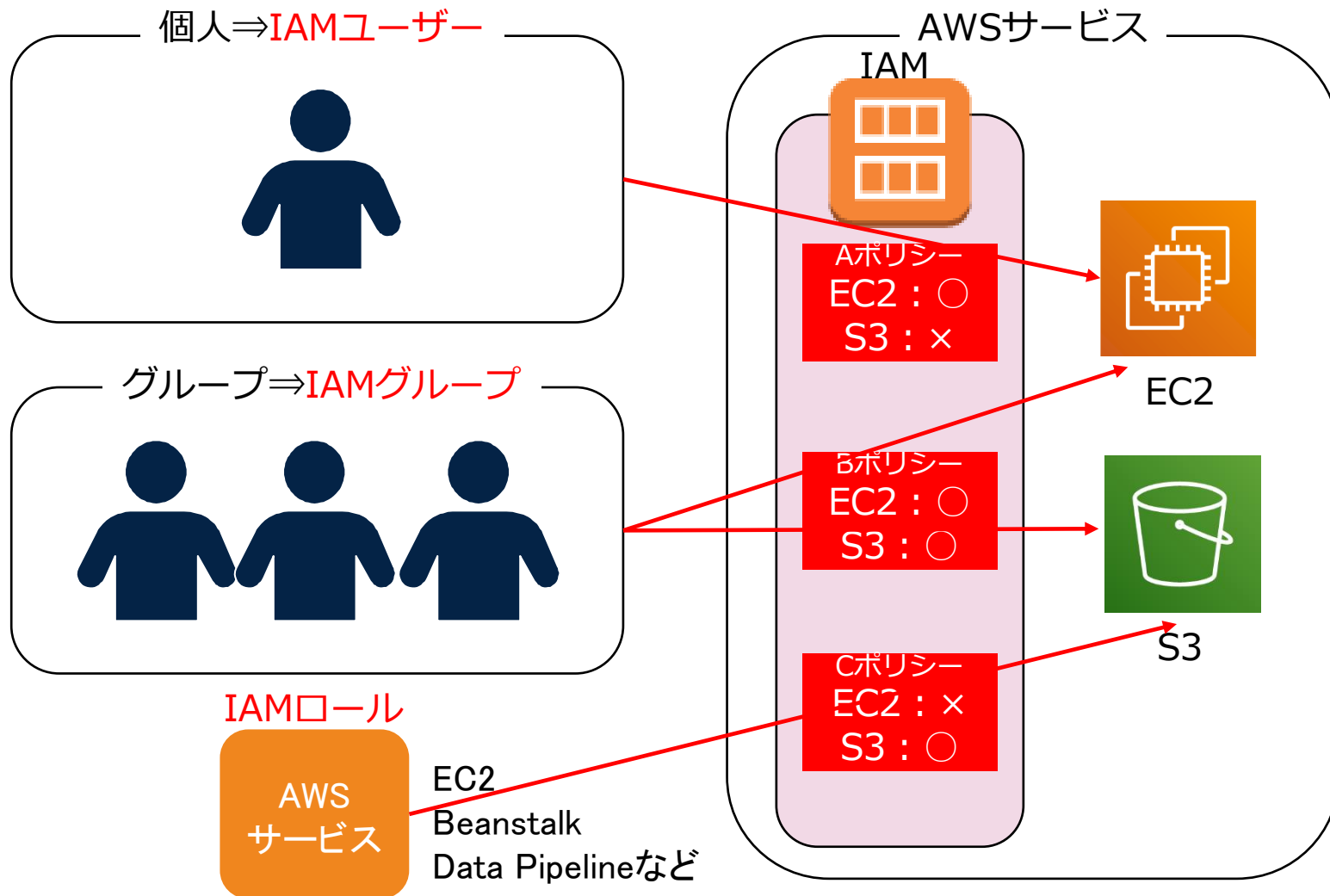
IAMグループ

グループとして権限をまとめて設定された単位のこと。グループには通常は複数のIAMユーザーが設定される



IAMロール

AWSリソースに対してアクセス権限をロールとして付与できる



IAMで使われる用語

IAMで利用される専門用語が似通っているため、違いをおさえることが重要

IAM リソース	✓ IAMで保存・管理されるユーザー、グループ、ロール、ポリシー、および IDプロバイダー
IAM アイデンティティ	✓ ユーザー、グループおよびロール ✓ AWSで認証されてグループ化に使用される IAM リソースオブジェクトのこと
IAM エンティティ	✓ ユーザーおよびロール ✓ AWSに認証される IAMリソースオブジェクト
プリンシパル	✓ ルートユーザー、IAM ユーザー、または IAM ロールを使用する人またはアプリケーション ✓ フェデレーティッドユーザーと引き受けたロールも含まれる

IAMポリシー

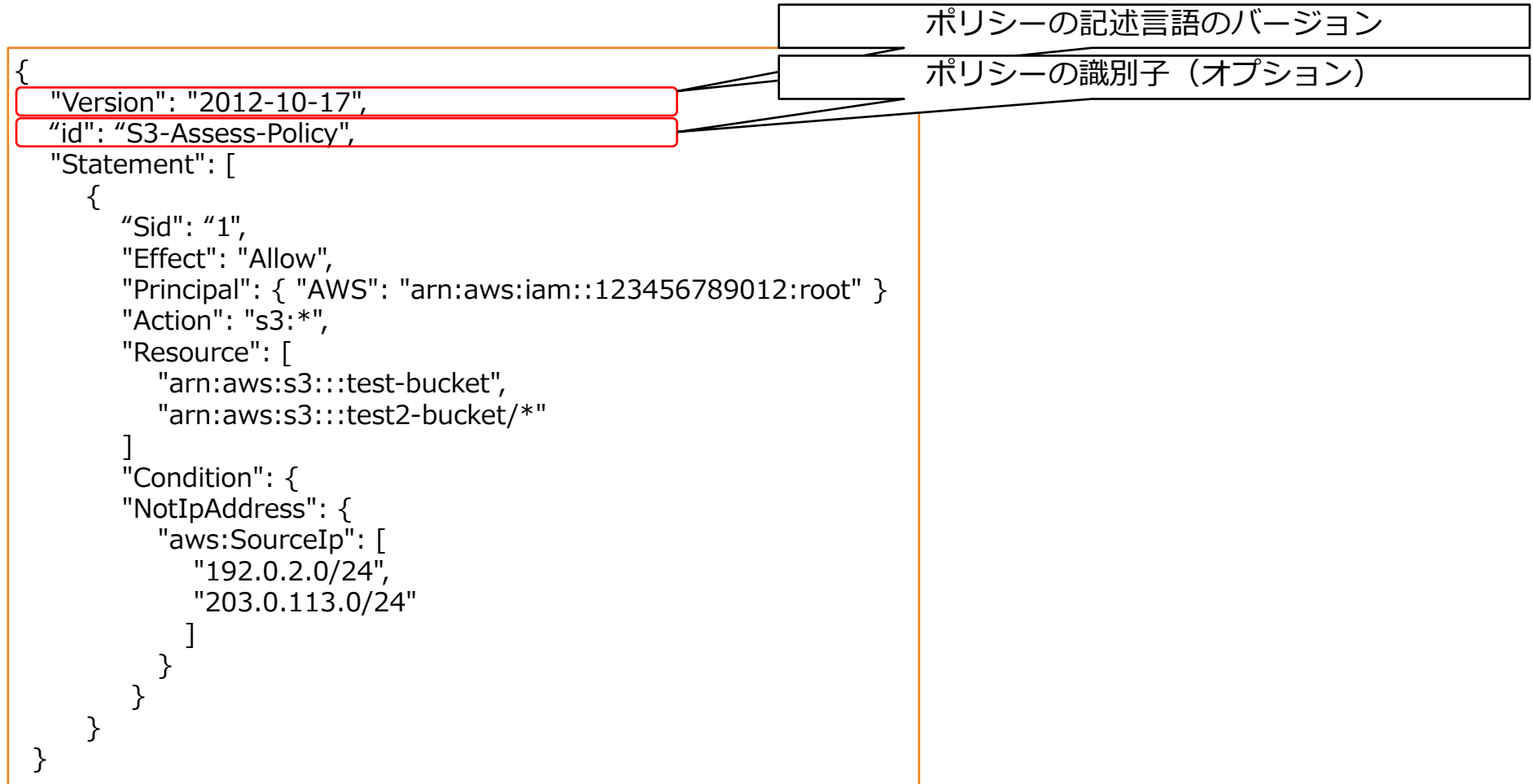
IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント

ポリシーの記述言語のバージョン

```
{
  "Version": "2012-10-17",
  "id": "S3-Assess-Policy",
  "Statement": [
    {
      "Sid": "1",
      "Effect": "Allow",
      "Principal": { "AWS": "arn:aws:iam::123456789012:root" },
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3:::test-bucket",
        "arn:aws:s3:::test2-bucket/*"
      ]
    }
  ],
  "Condition": {
    "NotIpAddress": {
      "aws:SourceIp": [
        "192.0.2.0/24",
        "203.0.113.0/24"
      ]
    }
  }
}
```

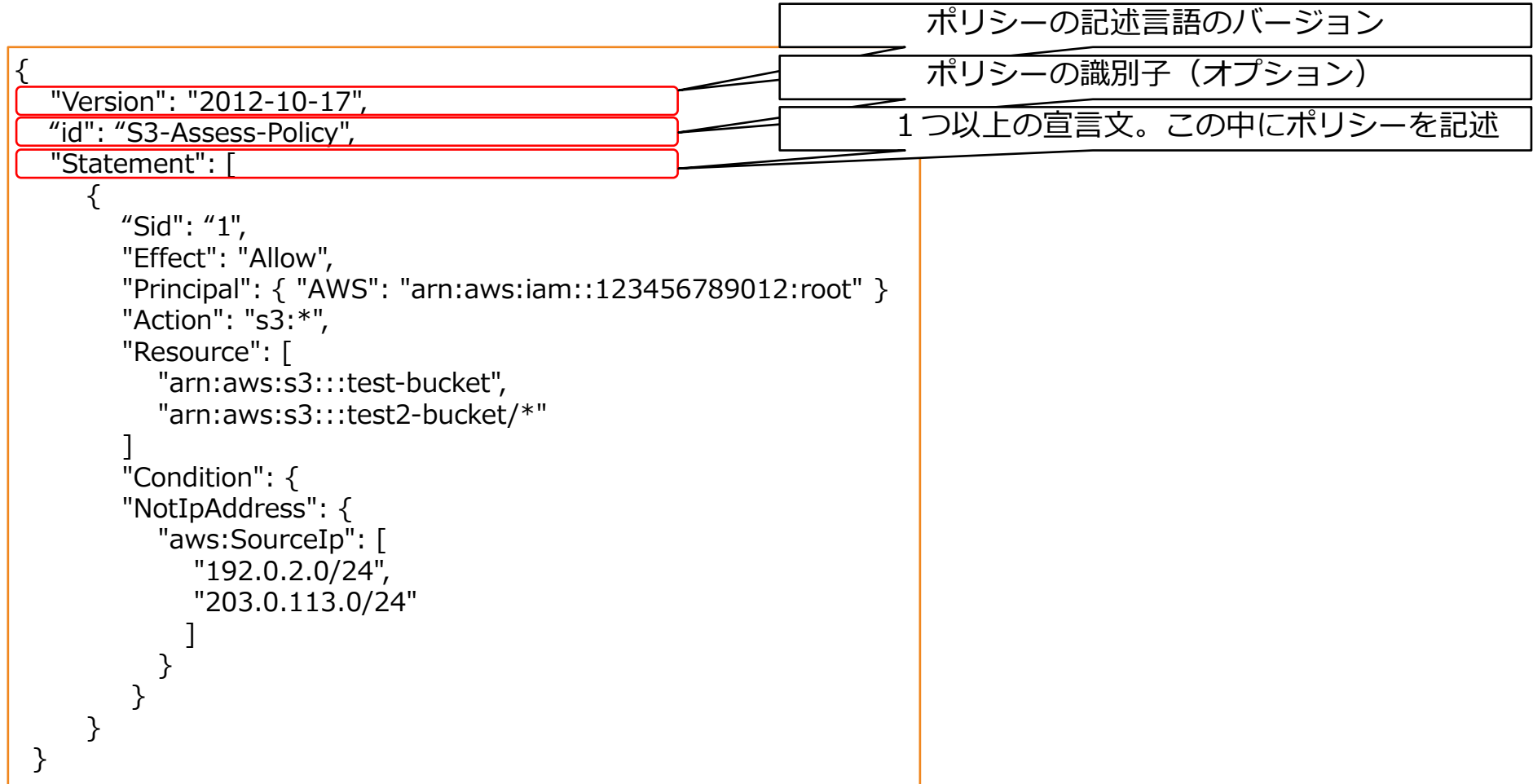
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



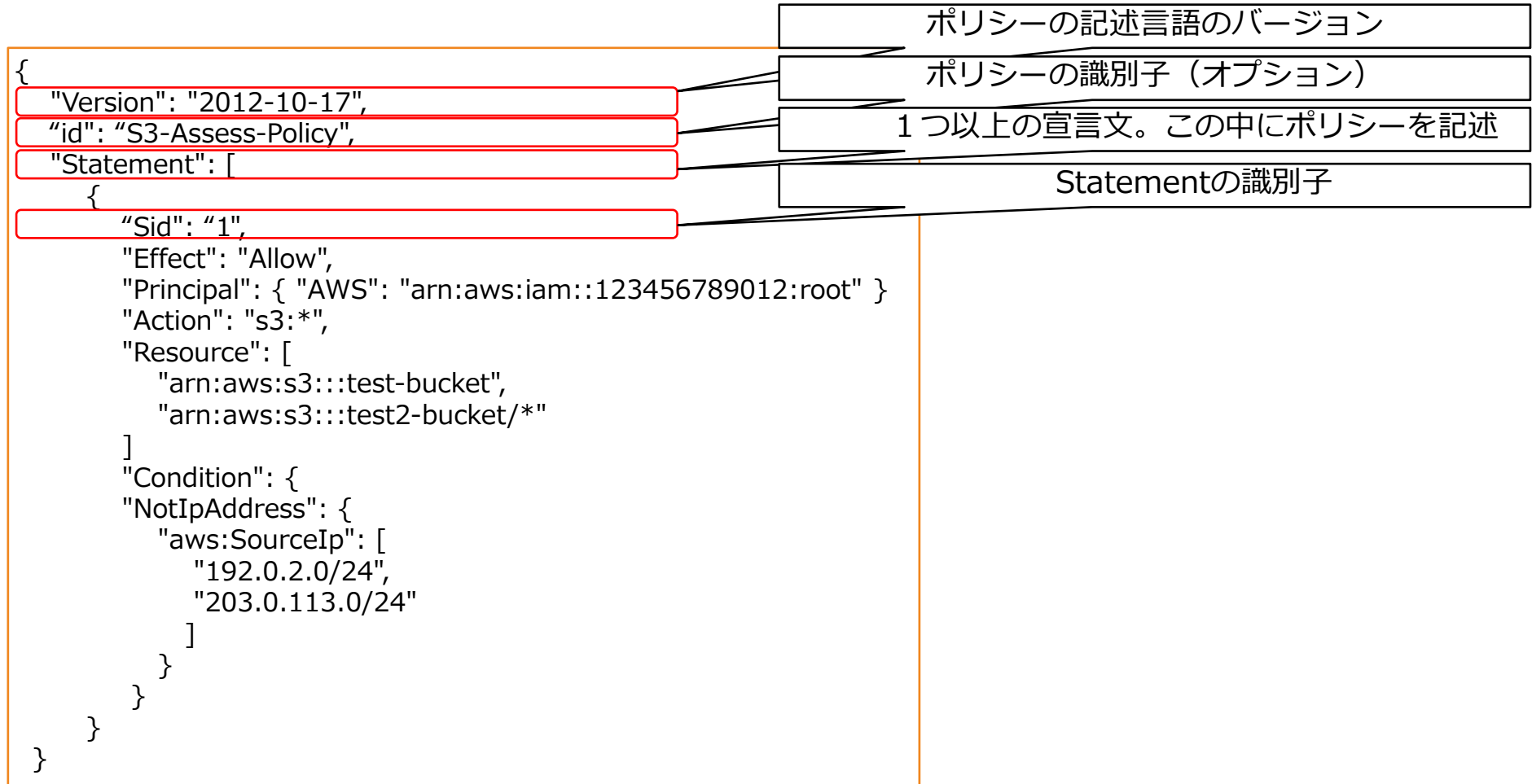
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



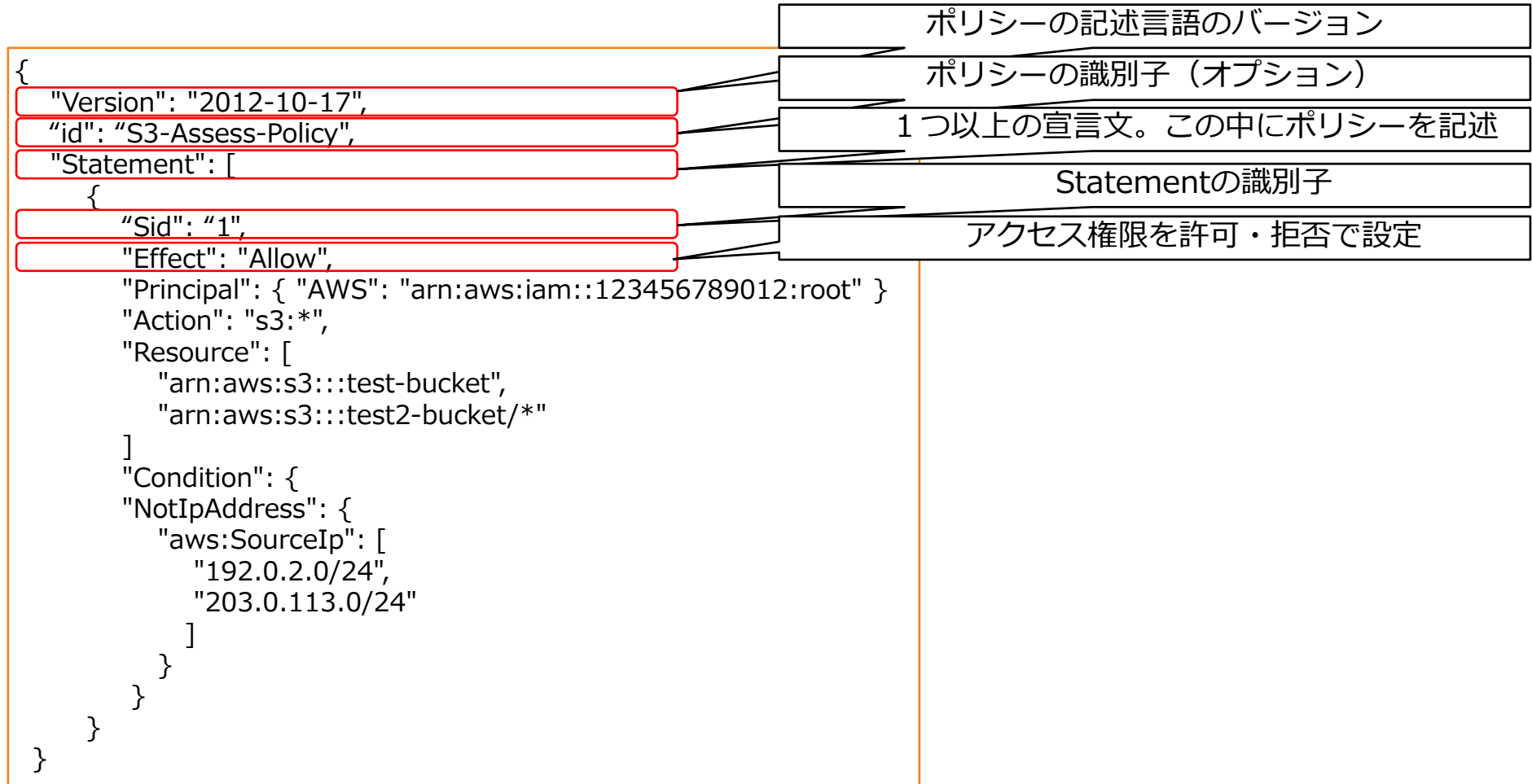
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



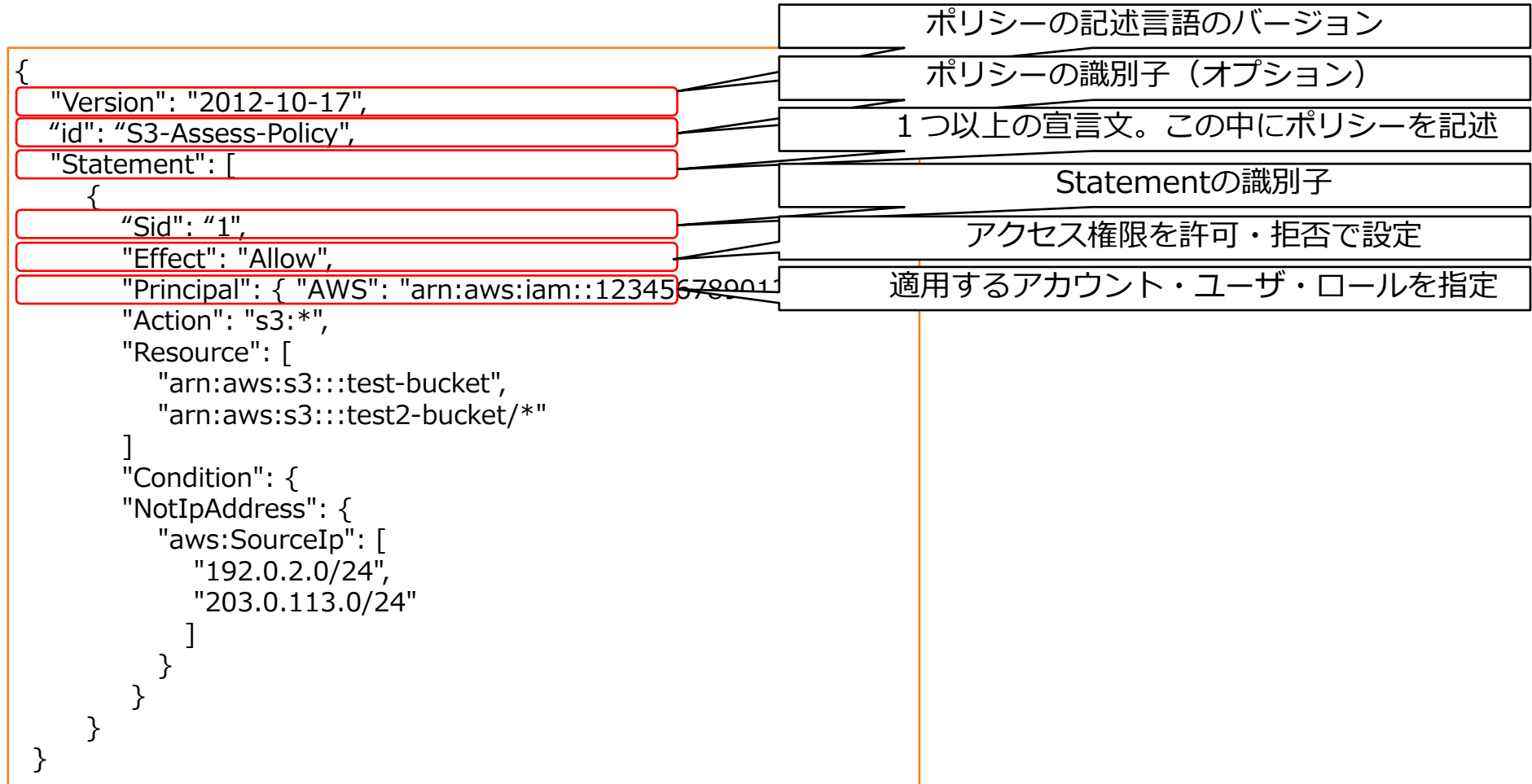
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



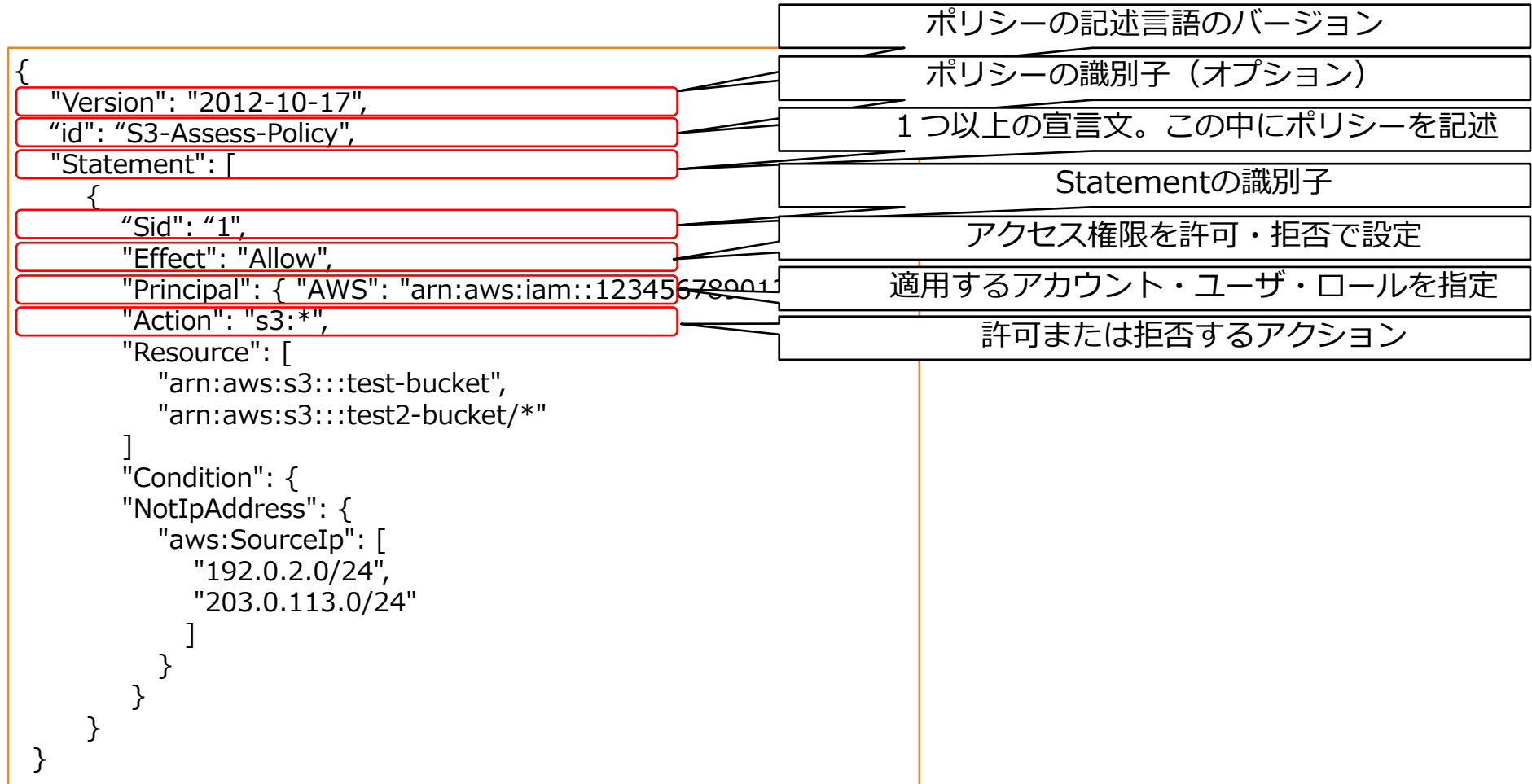
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



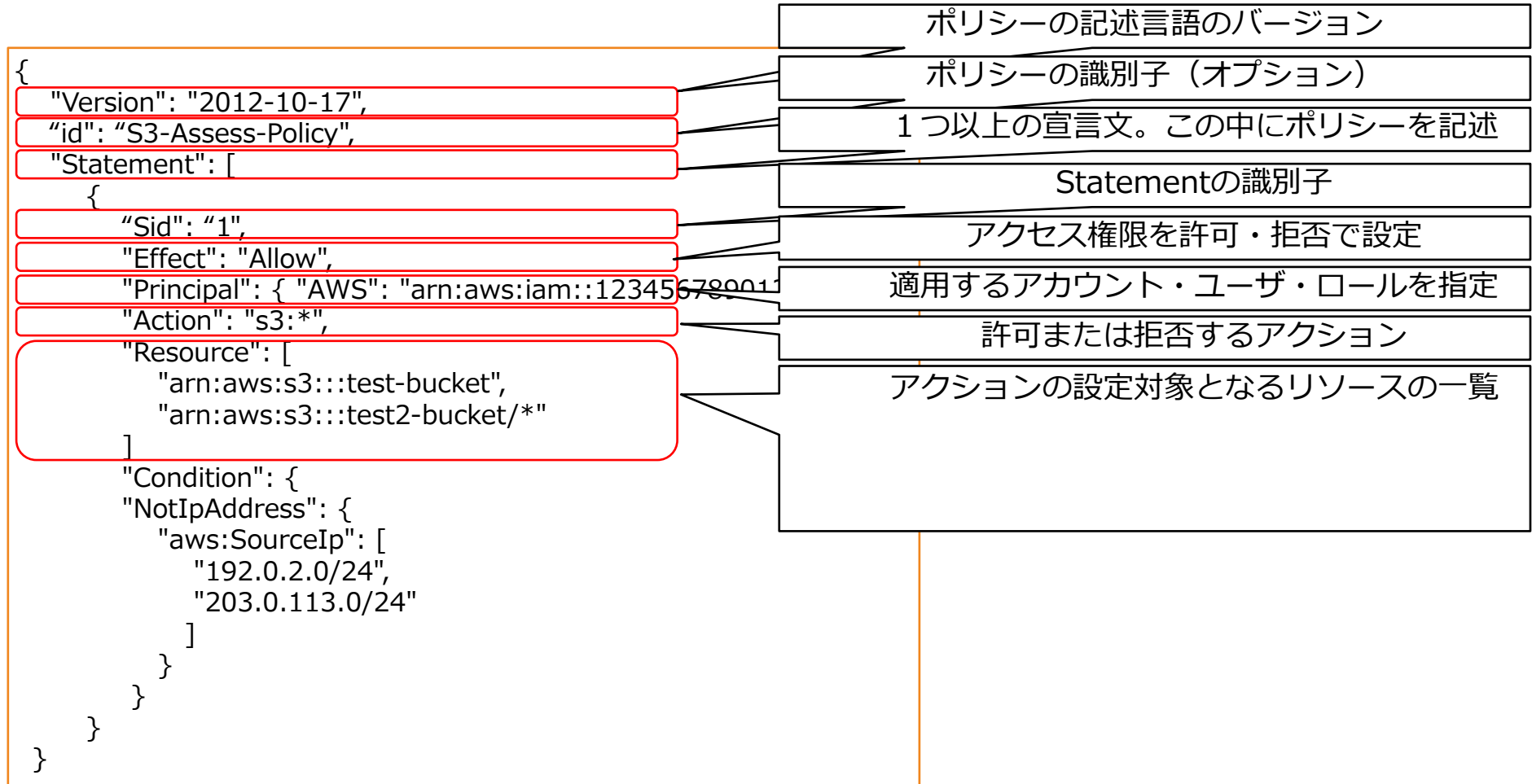
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



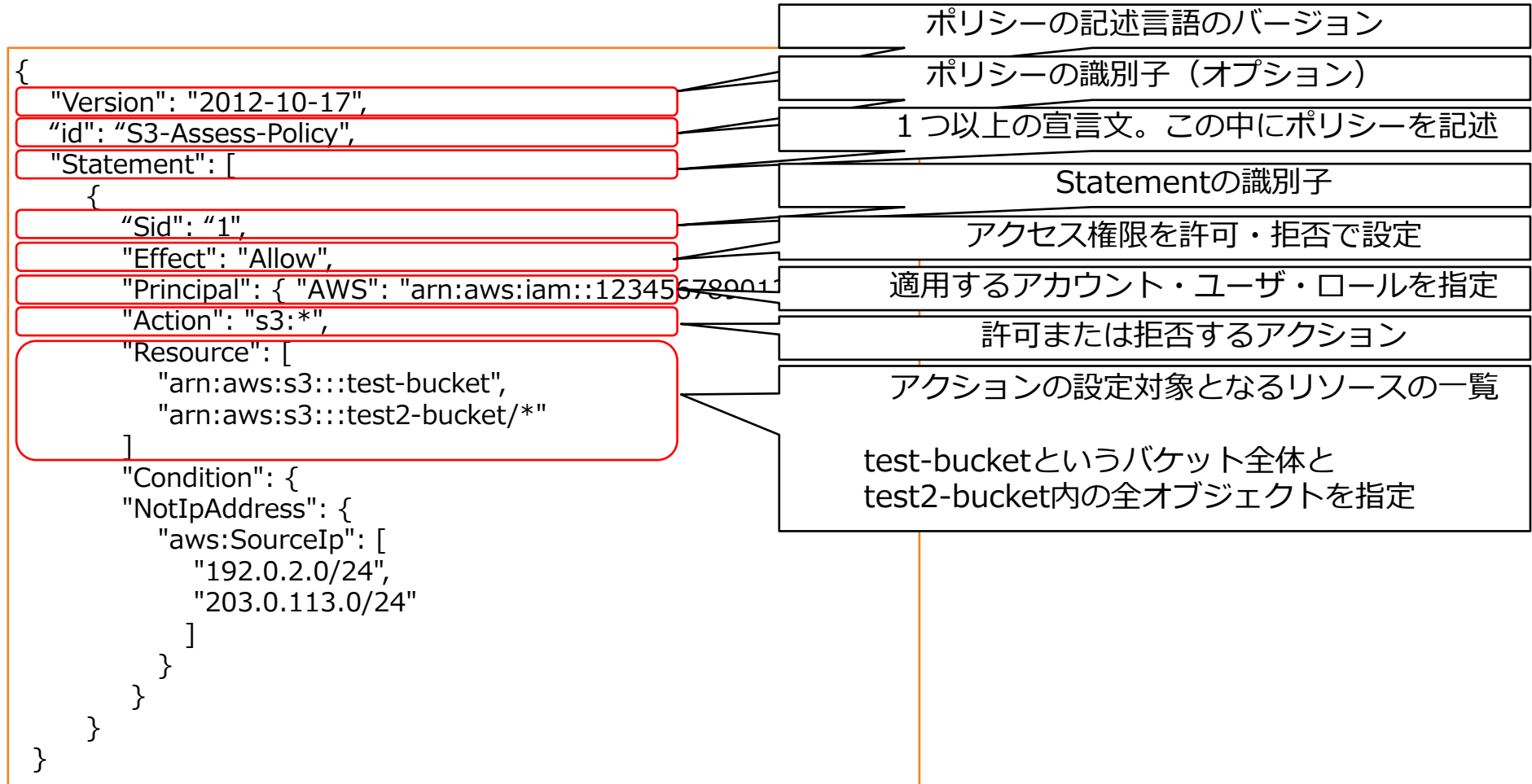
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



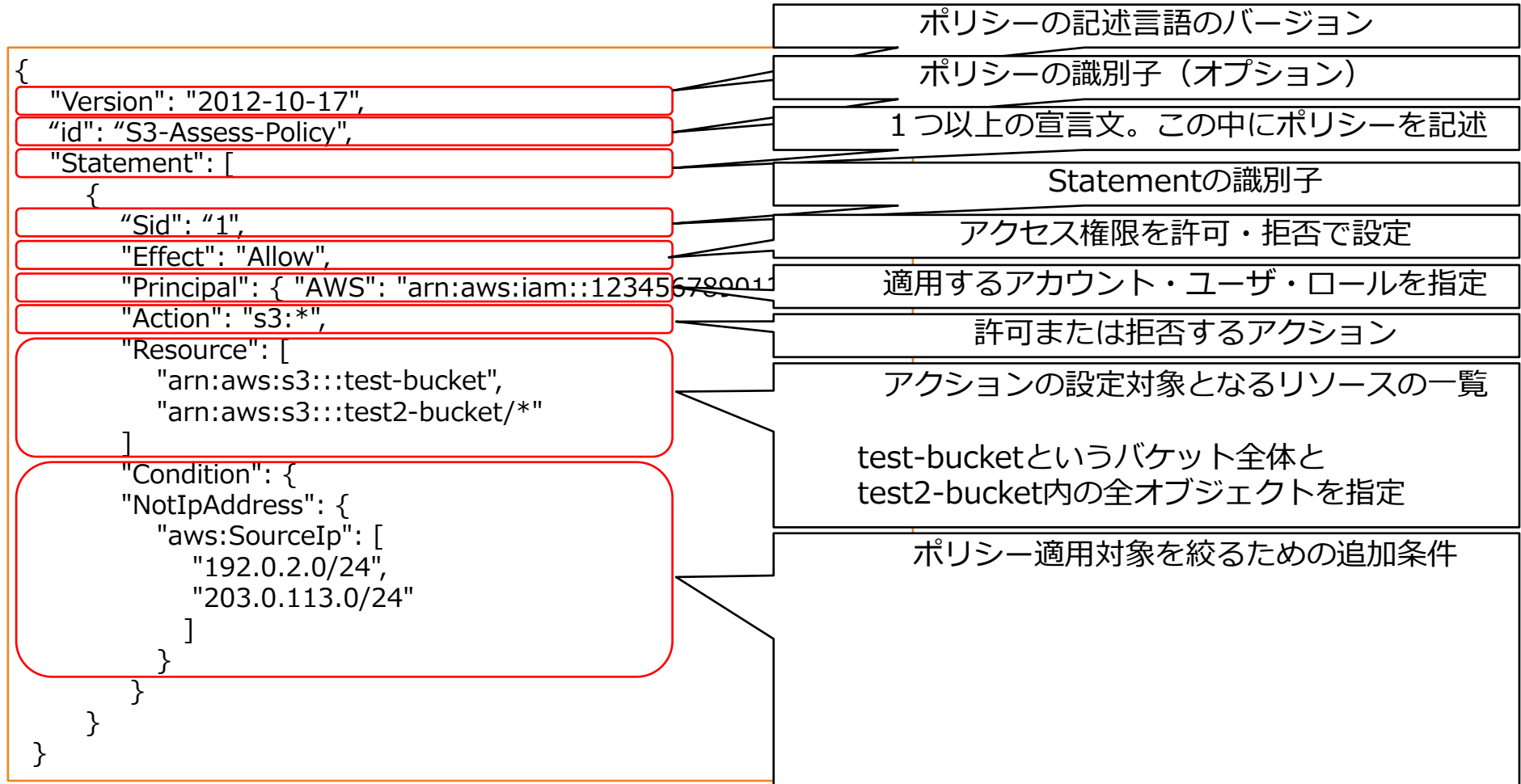
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



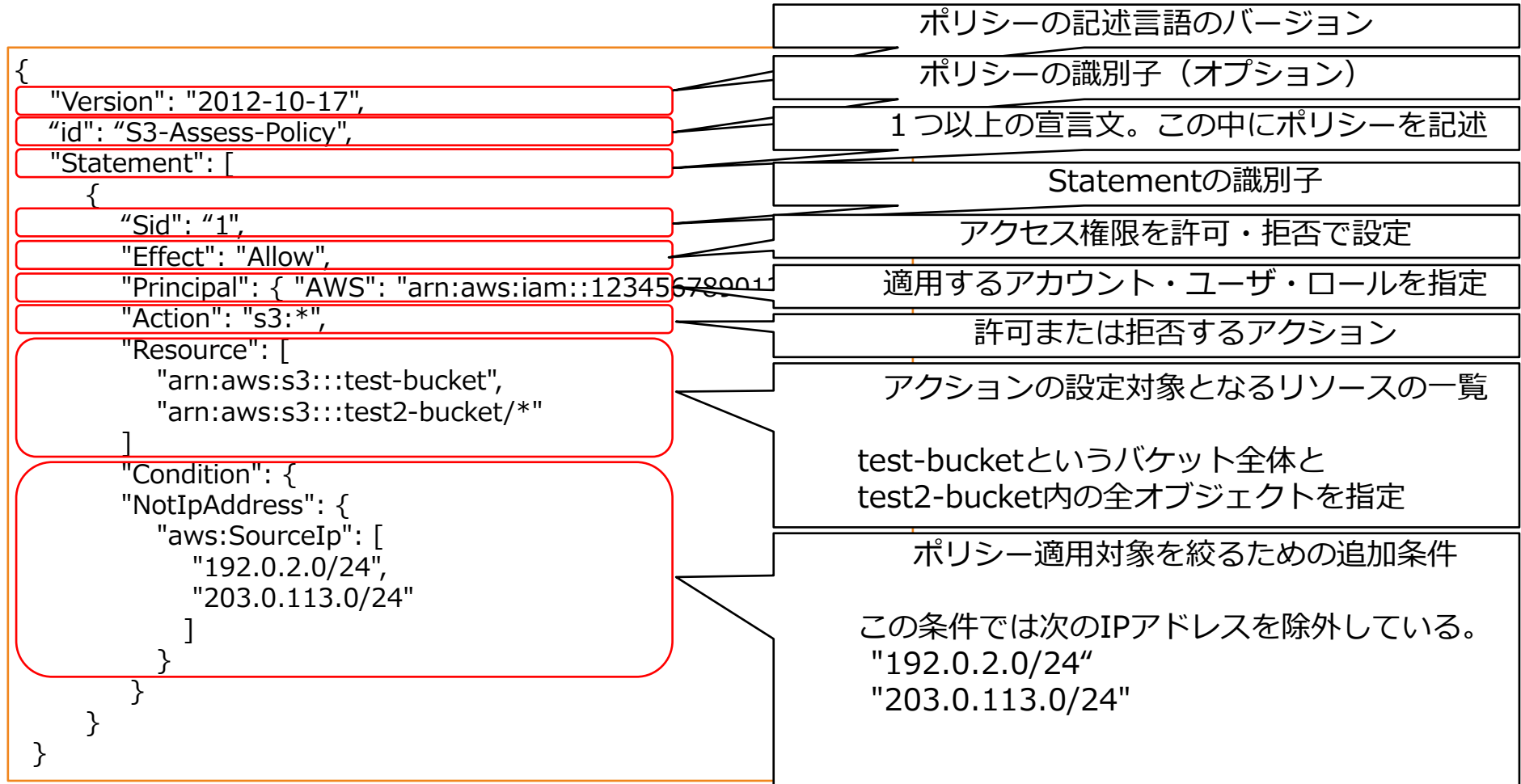
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



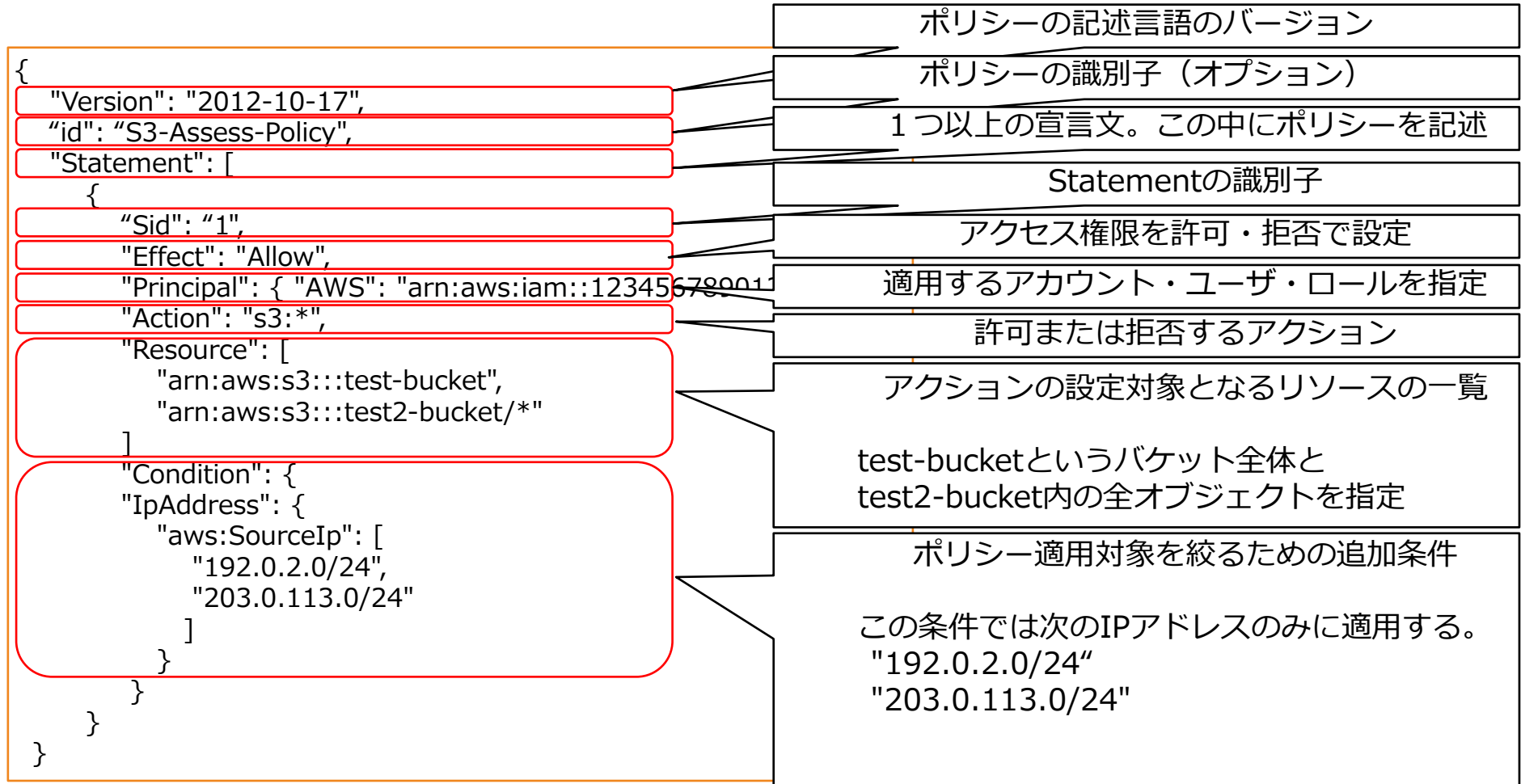
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



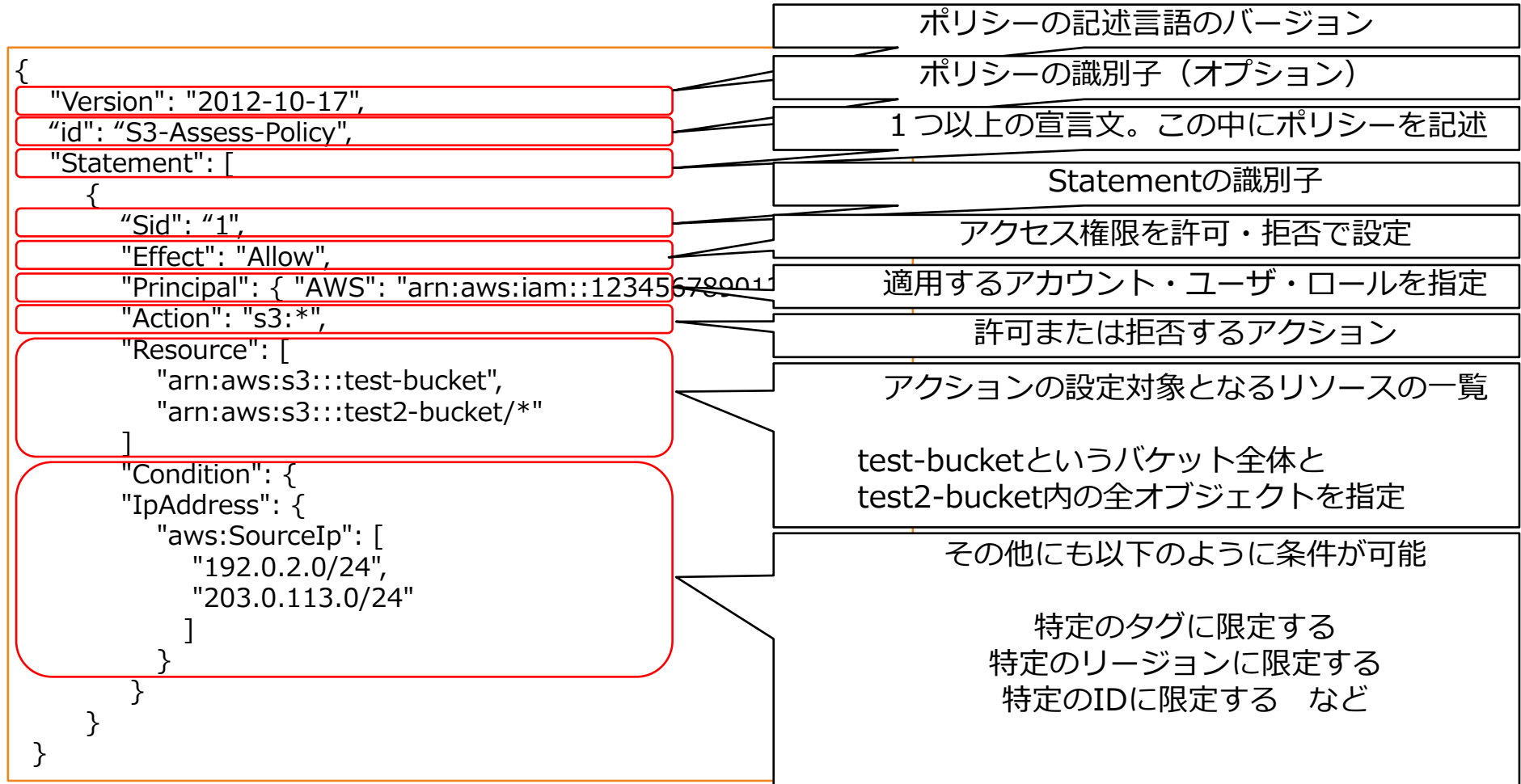
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



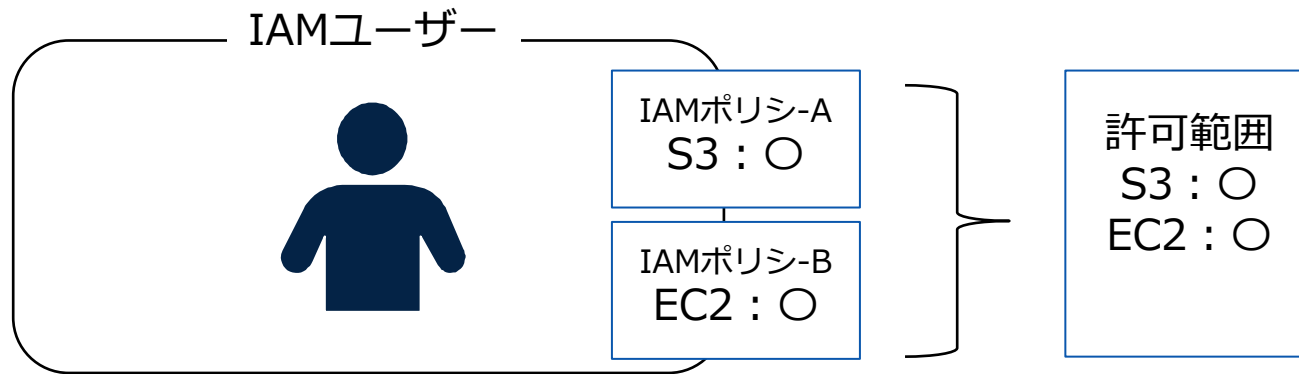
IAMポリシー

IAMポリシーはJSON形式でAWSリソースへのアクセス権限を設定するドキュメント



IAMポリシーの複数適用

IAMユーザーには複数のポリシーを適用可能。両方の許可範囲が権限となる。



IAMポリシーのタイプ

利用するIAMポリシーには管理ポリシーとインラインポリシーがある

管理ポリシー

【AWS管理ポリシー】

AWSが作成および管理しているIAM管理ポリシー
既にAWSが設定しているポリシーがリスト化されており、適時ユーザーやロールに適用できる。

【カスタマー管理ポリシー】

AWSアカウントで作成・管理する管理ポリシー。
同じポリシーを複数のIAMエンティティにアタッチできる

インラインポリシー

1つのプリンシパルエンティティ（ユーザー、グループ、またはロール）に埋め込まれた固有ポリシーで、プリンシパルエンティティにアタッチすることができる

管理ポリシー

IAMユーザーやロールに対して権限を付与する際に通常利用するポリシー

- ✓ 再利用可能性
1つの管理ポリシーを複数のプリンシパルエンティティ（ユーザー、グループ、ロール）にアタッチして利用可能
- ✓ 一元化された変更管理
管理ポリシーを変更すると、変更はポリシーがアタッチされているすべてのプリンシパルエンティティに適用される。
- ✓ バージョニングとロールバック
カスタマー管理ポリシーを変更しても、変更されたポリシーによって既存のポリシーが上書きされずに新しいバージョンを作成する。
- ✓ アクセス許可管理の委任
ポリシーで定義されたアクセス許可を制御しながら、AWS アカウントのユーザーにポリシーのアタッチとデタッチを許可できる

管理ポリシー

通常は管理ポリシーを使用する。AWS管理ポリシーを優先して利用し、ない場合にカスタマー管理ポリシーを作成する。

AWS管理ポリシー

IAM > ポリシー

ポリシー (961) **情報**

ポリシーはアクセス許可を定義する AWS のオブジェクトです。

🔄 アクション **ポリシーの作成**

🔍 ポリシーを ID/パーティまたはポリシー名でフィルタし、Enter キーを押します。

ポリシー名	タイプ	として使用	説明
☐  AWSDirectConnectReadOnlyAccess	AWS 管理	なし	Provides read
☐  AmazonGlacierReadOnlyAccess	AWS 管理	なし	Provides read
☐  AWSMarketplaceFullAccess	AWS 管理	なし	Provides the s
☐  ClientVPNServiceRolePolicy	AWS 管理	なし	Policy to enab
☐  AWSSSODirectoryAdministrator	AWS 管理	なし	Administrator
☐  AWSIoT1ClickReadOnlyAccess	AWS 管理	なし	Provides read
☐  AutoScalingConsoleReadOnlyAccess	AWS 管理	なし	Provides read
☐  AmazonDMSRedshiftS3Role	AWS 管理	なし	Provides acce
☐  AWSQuickSightListIAM	AWS 管理	なし	Allow QuickSi
☐  AWSHealthFullAccess	AWS 管理	なし	Allows full acc
☐  AlexaForBusinessGatewayExecution	AWS 管理	なし	Provide gatew
☐  AmazonElasticTranscoder_ReadOnlyAccess	AWS 管理	なし	Grants users i
☐  AmazonRDSFullAccess	AWS 管理	なし	Provides full s
☐  AmazonEC2FullAccess	AWS 管理	なし	Provides full s

管理ポリシー

通常は管理ポリシーを使用する。AWS管理ポリシーを優先して利用し、ない場合にカスタマー管理ポリシーを作成する。

AWS管理ポリシー

IAM > ポリシー

ポリシー (961) 情報

ポリシーはアクセス許可を定義する AWS のオブジェクトです。

Q ポリシーをフルバティまたはポリシー名でフィルタし、Enter キーを押します。

ポリシー名	タイプ	として使用	説明
AWSDirectConnectReadOnlyAccess	AWS 管理	なし	Provides read
AmazonGlacierReadOnlyAccess	AWS 管理	なし	Provides read
AWSMarketplaceFullAccess	AWS 管理	なし	Provides the s
ClientVPNServiceRolePolicy	AWS 管理	なし	Policy to enab
AWSSSODirectoryAdministrator	AWS 管理	なし	Administrator
AWSIoT1ClickReadOnlyAccess	AWS 管理	なし	Provides read
AutoScalingConsoleReadOnlyAccess	AWS 管理	なし	Provides read
AmazonDMSRedshiftS3Role	AWS 管理	なし	Provides acce
AWSQuickSightListIAM	AWS 管理	なし	Allow QuickSi
AWSHealthFullAccess	AWS 管理	なし	Allows full acc
AlexaForBusinessGatewayExecution	AWS 管理	なし	Provide gatew
AmazonElasticTranscoder_ReadOnlyAccess	AWS 管理	なし	Grants users i
AmazonRDSFullAccess	AWS 管理	なし	Provides full s
AmazonEC2FullAccess	AWS 管理	なし	Provides full s

カスタマー管理ポリシー

ポリシーの作成

1 2 3

ポリシーにより、ユーザー、グループ、またはロールに割り当てることのできる AWS アクセス権限が定義されます。ビジュアルエディタで JSON を使用してポリシーを作成または編集できます。 [詳細はこちら](#)

ビジュアルエディタ JSON 管理ポリシーのインポート

すべて展開 | すべて折りたたむ

サービスの選択 クローン 削除

サービス サービスの選択

アクション アクションを定義する前に、サービスを選択する

リソース リソースを適用する前に、アクションを選択する

リクエスト条件 条件を指定する前にアクションを選択する

さらにアクセス許可を追加する

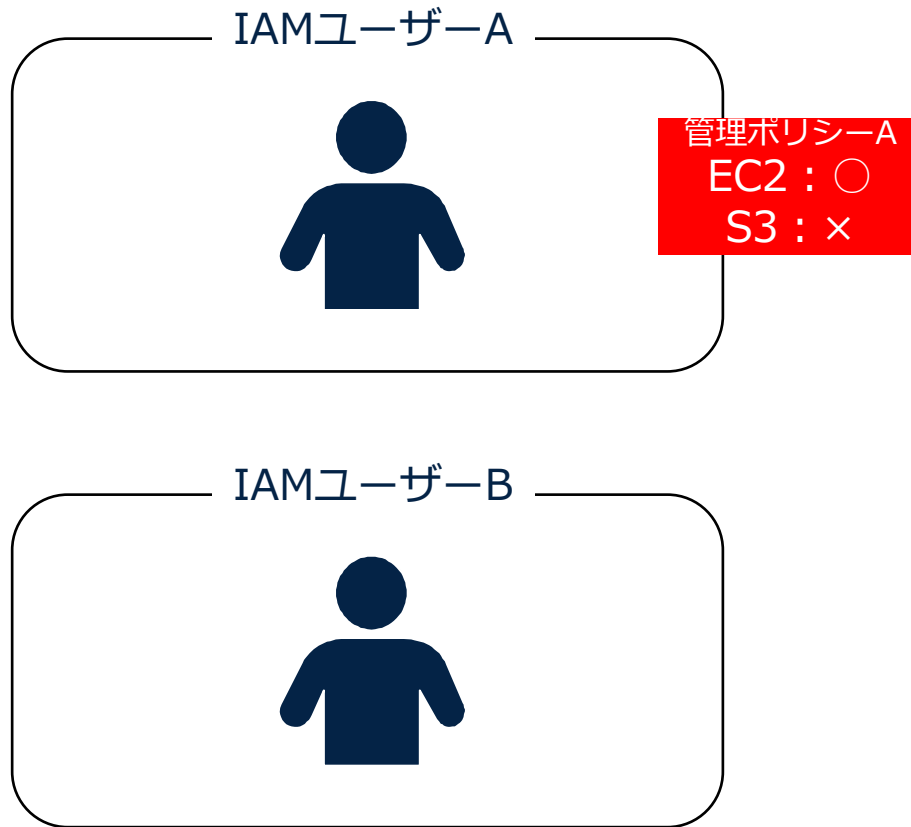
インラインポリシー

インラインポリシーはポリシーとそれが適用されている ID との厳密な 1 対 1 の関係を維持する場合に利用する

- ✓ 管理ポリシーと異なり再利用ができずに 1 つのアイデンティティにしか適用できないポリシー
- ✓ 本質的にアイデンティティ（ユーザー、グループ、またはロール）の一部となっている。
- ✓ ポリシー内のアクセス権限が意図したアイデンティティ以外のアイデンティティに間違って割り当てられないようにする。
- ✓ 付与したアイデンティティを削除すると、そのアイデンティティに組み込まれたポリシーも削除される。
- ✓ アカウントにインラインポリシーがある場合は、管理ポリシーに変換することができる。

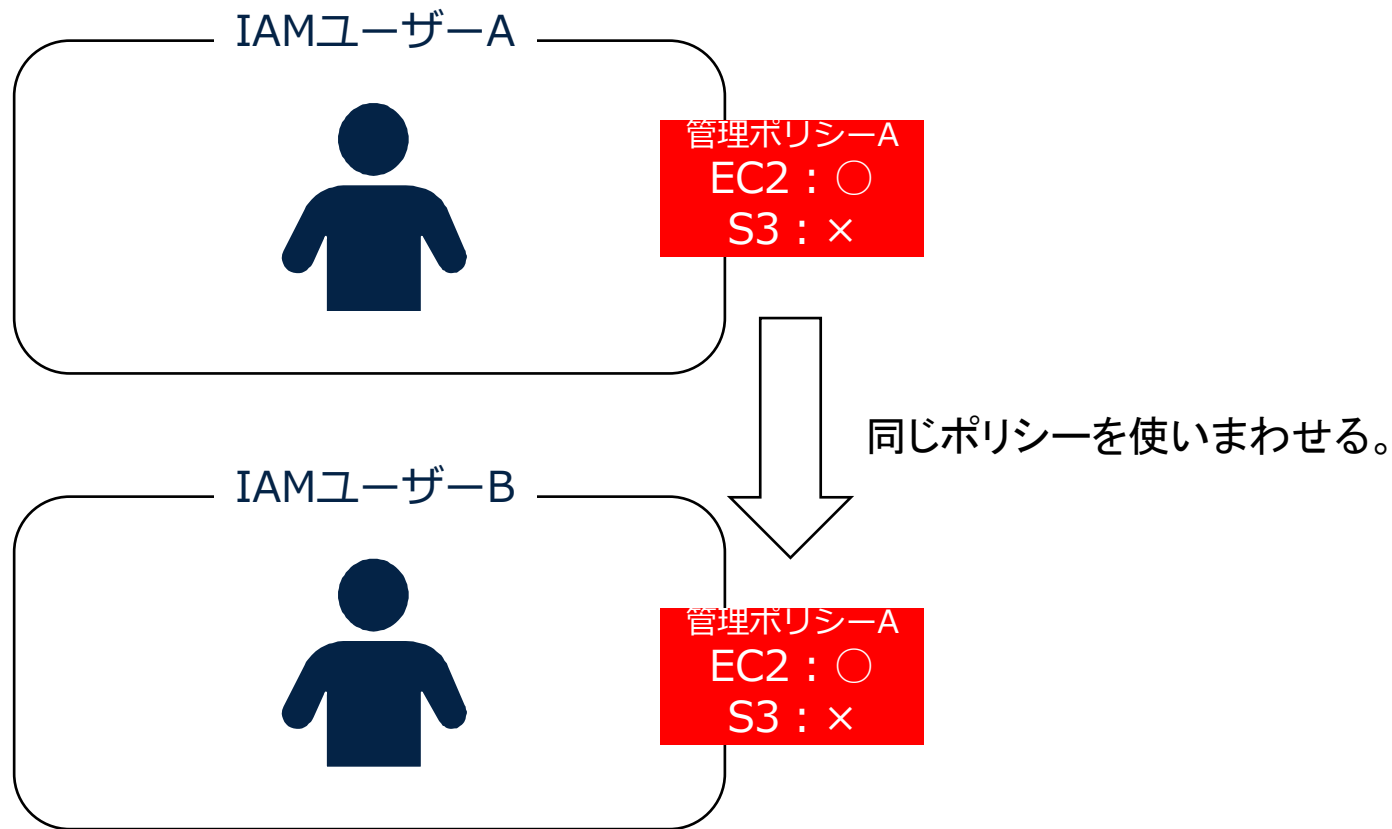
管理ポリシー

管理ポリシーは1つのポリシーを様々なユーザーやリソースに
使いまわせるポリシー



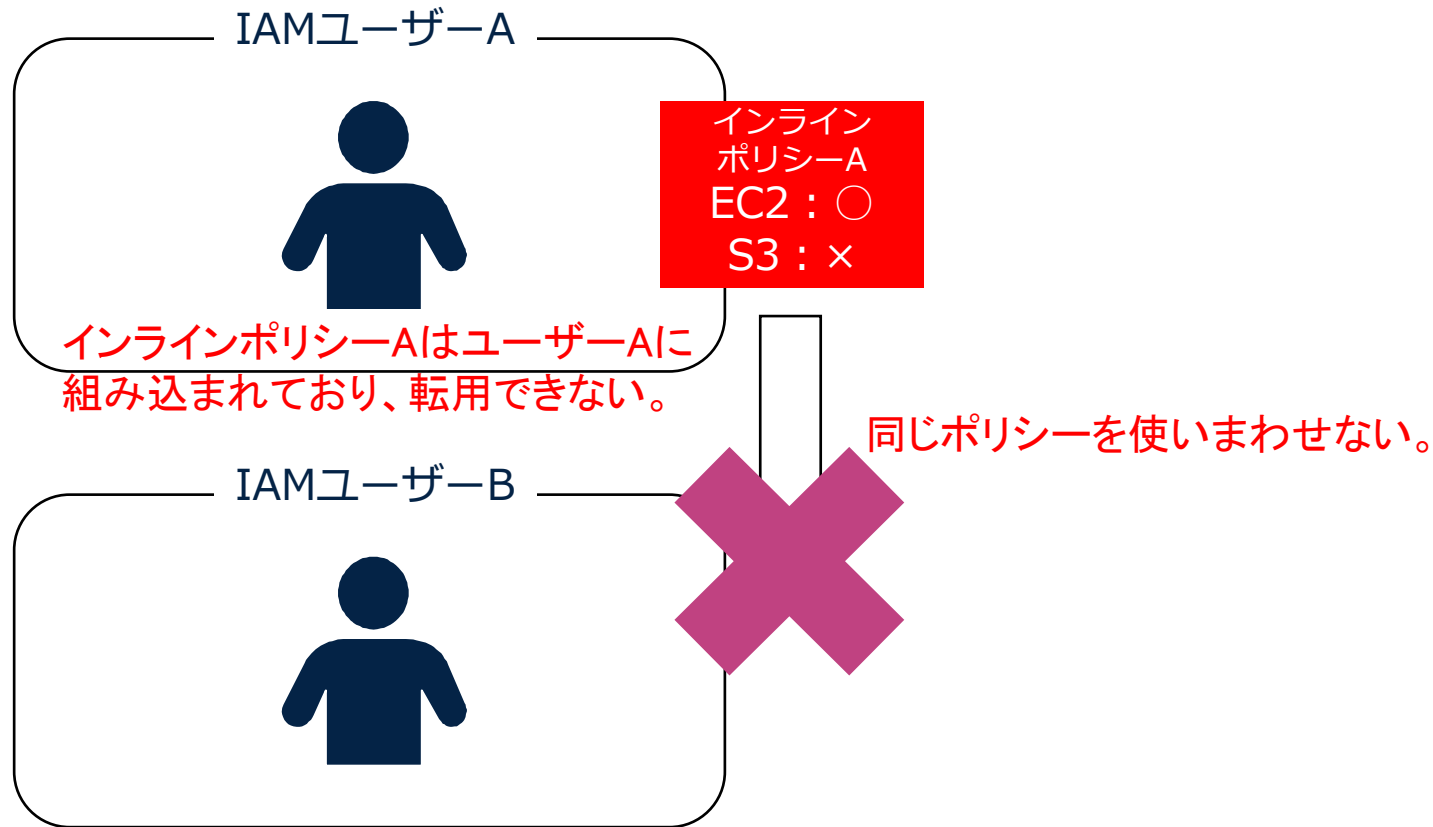
管理ポリシー

管理ポリシーは1つのポリシーを様々なユーザーやリソースに使いまわせるポリシー



インラインポリシー

インラインポリシーは他のユーザーやリソースに使いまわせない、特定のユーザーやリソースに組み込まれるポリシー。



ポリシーのタイプ

IAMポリシーはユーザーベースのポリシーと呼ばれるポリシーであり、他にも多数のポリシーが存在する。

ユーザーベース (アイデンティティベース) のポリシー

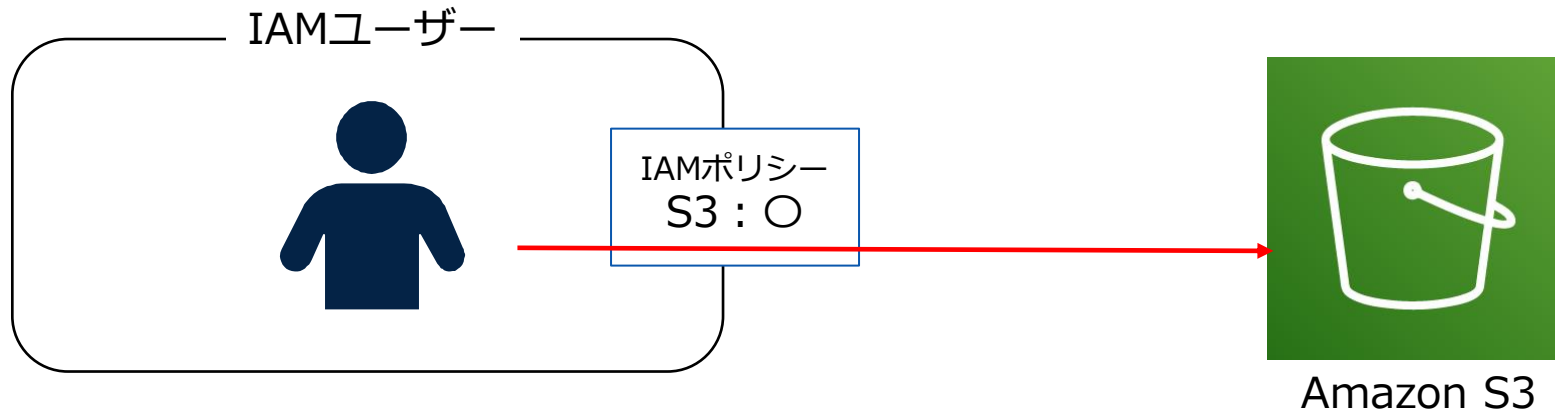
- ✓ IAMアイデンティティ(ユーザー、ユーザーのグループ、ロール) にアタッチされるポリシー
- ✓ つまり、管理ポリシーとインラインポリシーなど
- ✓ そのアイデンティティが実行できる内容 (そのアクセス許可) を指定できる。

リソースベースの ポリシー

- ✓ AWSリソースにアタッチされるポリシーであり、リソースに対するアクセス権限設定を実行する
- ✓ 例えばAmazon S3のバケットポリシー、ロールの信頼ポリシー
- ✓ JSON形式のドキュメントで定義されたインラインポリシーをリソースにアタッチして利用する。

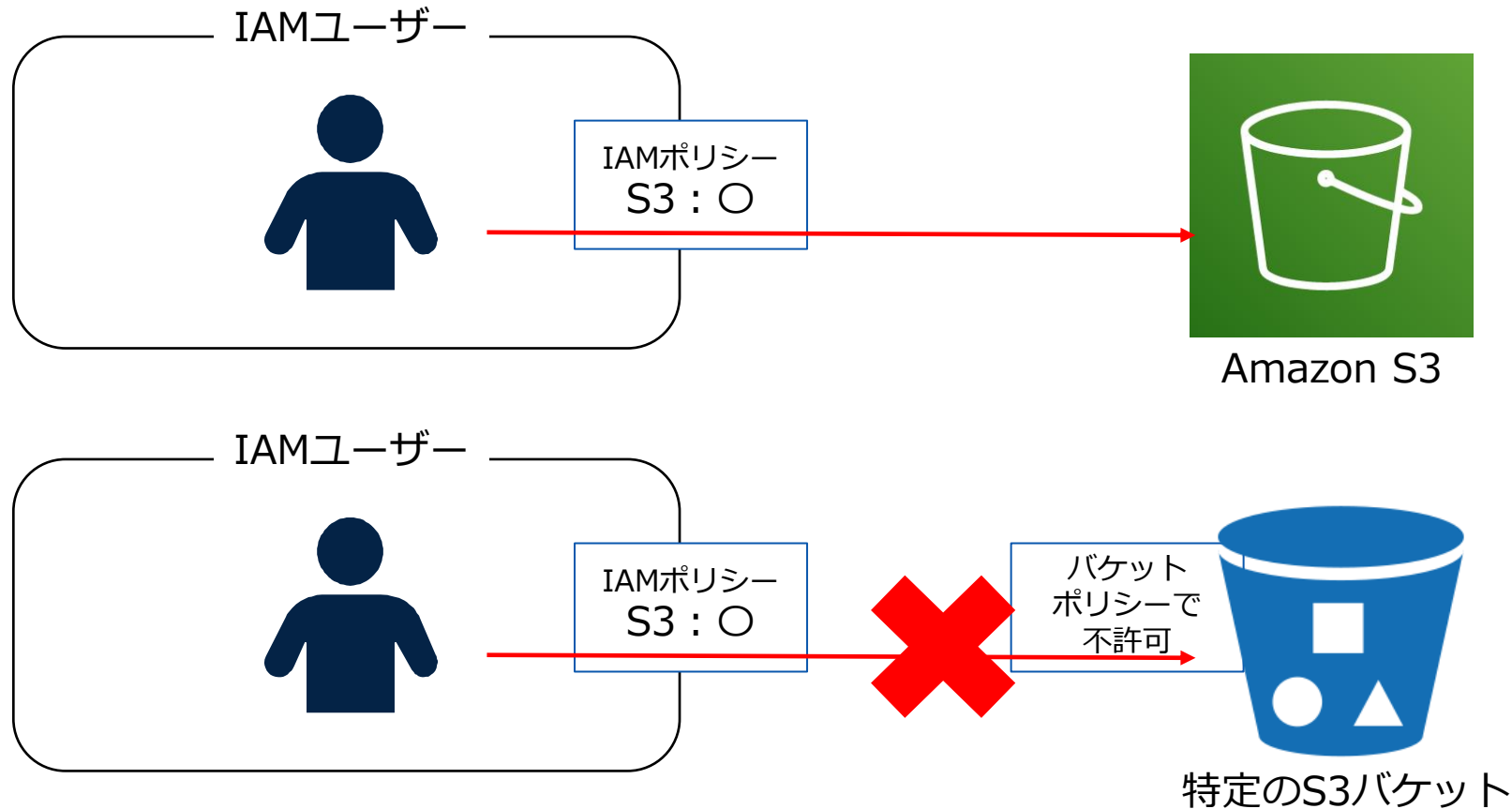
IDベースのポリシー

アイデンティティベースのポリシーにより、特定のAWSリソースへの操作権限が付与される。



リソースベースのポリシー

リソースベースのポリシーにより、特定のリソース範囲のアクセスをリソース側から制御する。



ポリシー効果

ポリシーの効果として、許可を与えるポリシーと信頼を与えるポリシーが存在する。

許可ポリシー

- ✓ AWSリソースへのアクセス許可・拒否を設定する通常のIAMポリシーのこと
- ✓ 許可するアクション範囲を設定する。

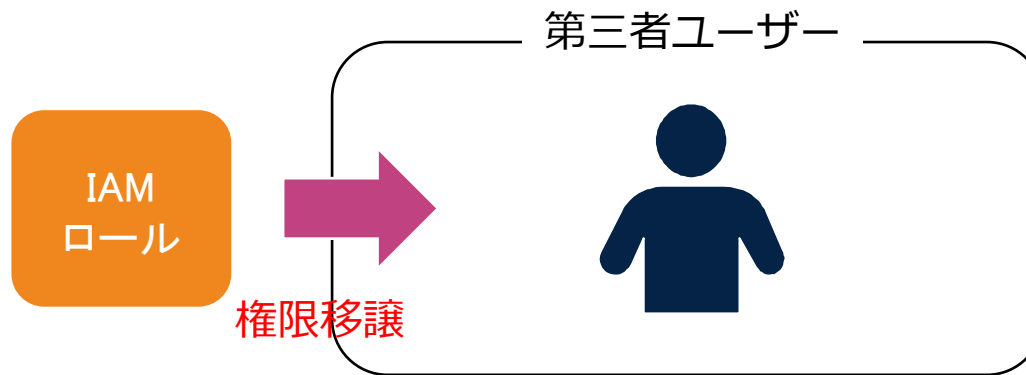
信頼ポリシー

- ✓ 特定のユーザーやリソースへのアクセスを許すための前提となる信頼を形成するためのポリシー
- ✓ 信頼ポリシーが付与されているロールに基づいて、権限を委譲することができる。

IAMロールの信頼ポリシー

IAMロールは監査人などに一時的な権限を委譲する際にも利用される。

- ✓ IAMロールの権限移譲操作に特化したポリシー
- ✓ 当該の信頼ポリシーを関連づけたIAMロールが保有する権限を、信頼ポリシーの操作主体であるPrincipalに移譲(を許可)することができる。



ユーザーのアクティビティの記録

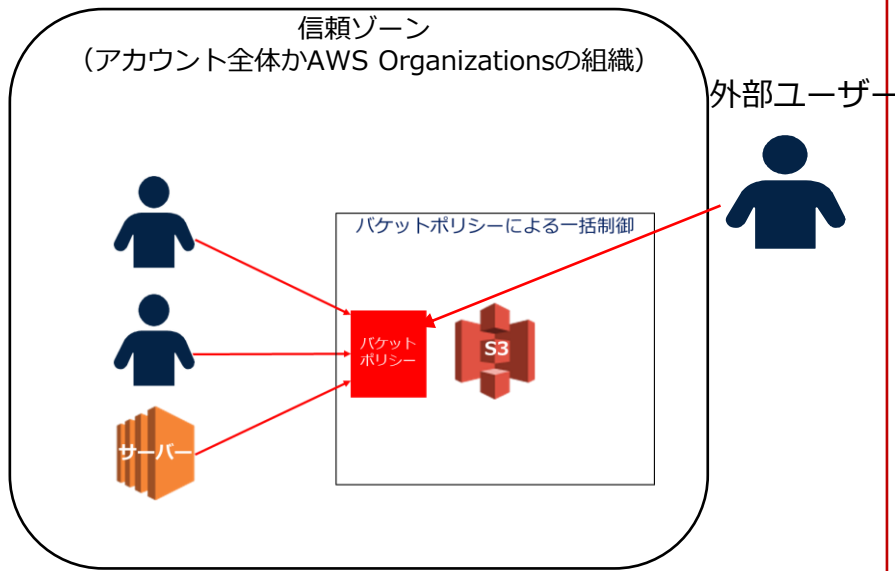
目的に応じて様々なツールを利用して記録を取得できる。

IAMアクセス アナライザー	S3 バケットや IAM ロールなどリソースベースのポリシーを確認して、信頼ゾーンの外からのアクセスの有無を特定する。
IAMアクセス アドバイザー	IAMユーザーのアクセス可能なリソースと最終アクセス日時を確認することができる。
Credential Report	すべてのユーザーの認証情報が記載されたレポート
AWS Config	AWS ConfigはIAMのユーザー、グループ、ロール、ポリシーの変更履歴、構成変更を管理するサービス
AWS CloudTrail	AWS CloudTrailは各種アカウントアクティビティやAPIコールをログに記録し、モニタリングするサービス

ユーザーのアクティビティの記録

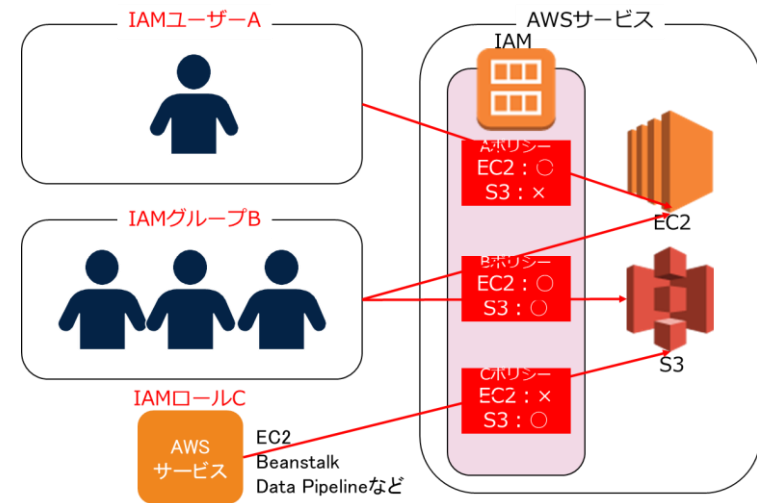
アクセスアナライザーは部外者アクセスの発見機能。アクセスアドバイザーは内部ユーザーのアクセス範囲の確認機能。

IAMアクセスアナライザー



外部ユーザーからのS3バケットへのアクセスが許可されている。

IAMアクセスアドバイザー



IAMユーザーAのアクセス範囲はEC2で○日○時にアクセスあり
IAMグループBのアクセス範囲はEC2とS3で○日○時にアクセスあり
IAMロールのアクセス範囲はS3で○日○時にアクセスあり

IAM権限のベストプラクティス

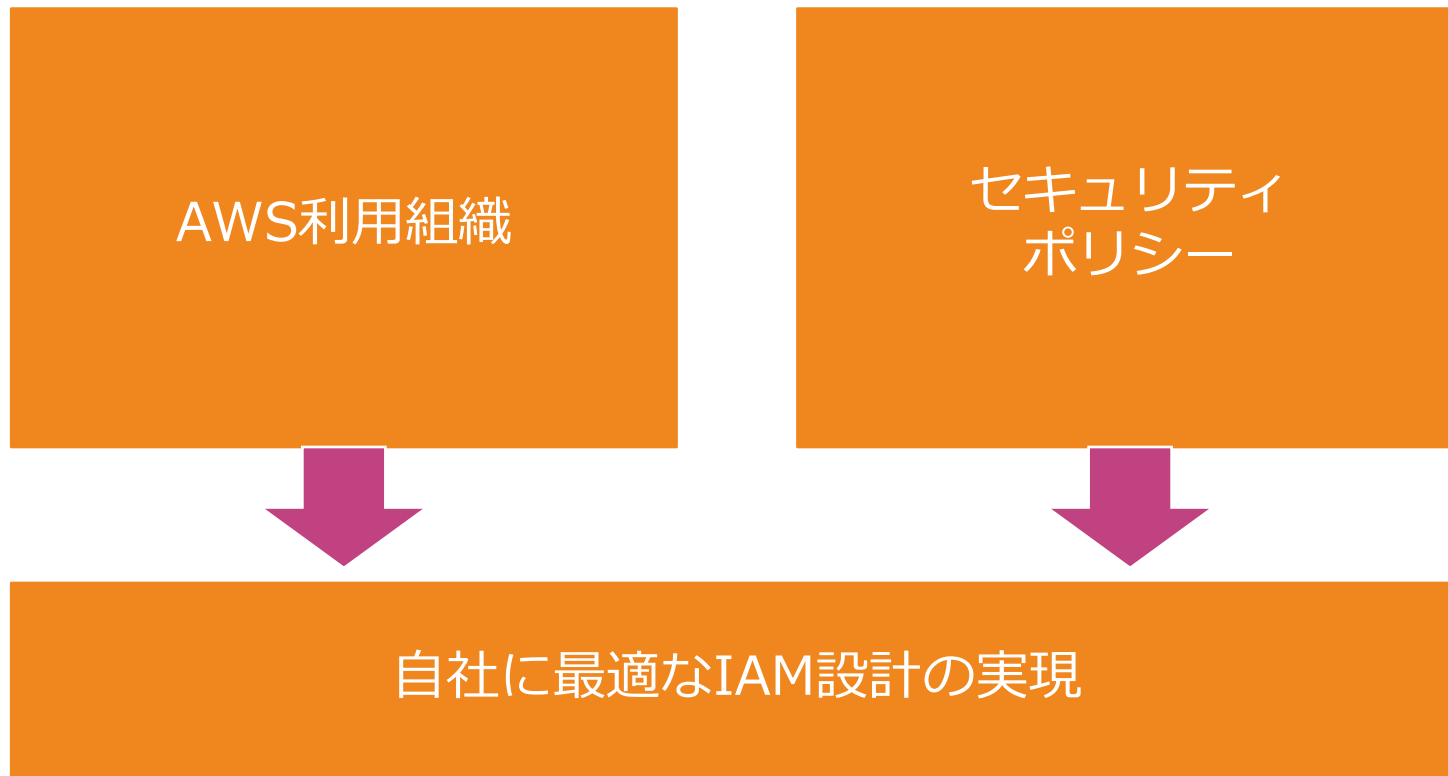
IAMを利用する際はベストプラクティスに沿った運用をする。

- ✓ 人間のユーザーが一時的な認証情報を使用して AWS にアクセスするには、ID プロバイダーとのフェデレーションの使用が必要です
- ✓ AWS にアクセスするには、ワークロードが IAM ロールを使用して一時的な資格情報を使用する必要があります
- ✓ 多要素認証 (MFA) が必要です
- ✓ 長期的な認証情報を必要とするユースケースのためにアクセスキーを定期的にローテーションする
- ✓ ルートユーザーの認証情報を保護し、日常的なタスクには使用しない
- ✓ 最小特権アクセス許可を適用する
- ✓ AWS 管理ポリシーの開始と最小特権のアクセス許可への移行
- ✓ IAM Access Analyzer を使用して、アクセスアクティビティに基づいて最小特権ポリシーを生成する
- ✓ 未使用のユーザー、ロール、アクセス許可、ポリシー、および認証情報を定期的を確認して削除する
- ✓ IAM ポリシーで条件を指定して、アクセスをさらに制限する
- ✓ IAM Access Analyzer を使用して、リソースへのパブリックアクセスおよびクロスアカウントアクセスを確認する
- ✓ IAM Access Analyzer を使用して IAM ポリシーを検証し、安全で機能的なアクセス許可を確保する
- ✓ 複数のアカウントにまたがるアクセス許可のガードレールを確立する
- ✓ アクセス権限の境界を使用して、アカウント内のアクセス許可の管理を委任します。

IAM設計

IAM設計

AWSを利用するユーザの役割やアクセス権限を自社の組織構造と合わせて設計することが重要



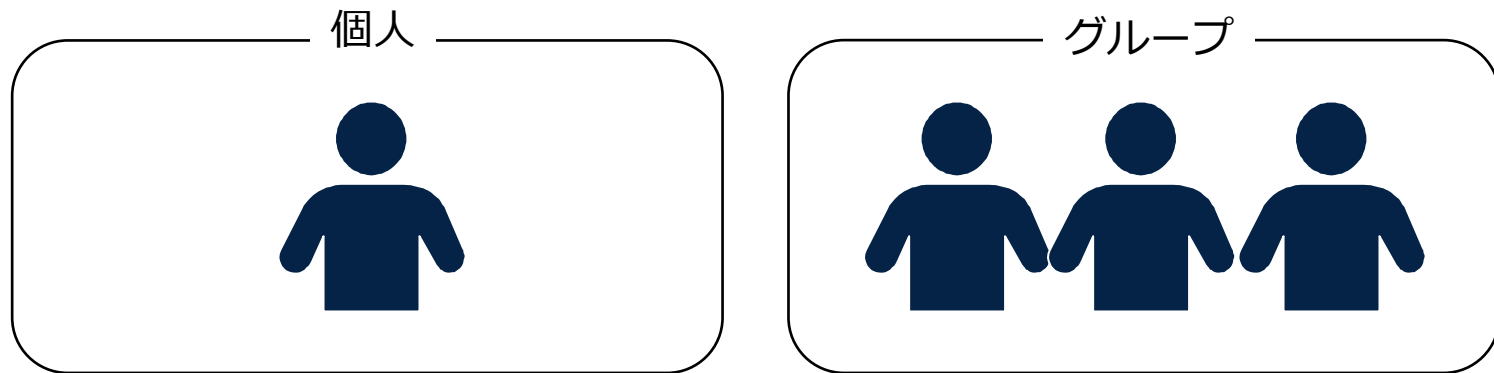
IAM設計のベストプラクティス

ベストプラクティスに沿ったIAM設計をすることが望ましい

1. アカウント設定などの必要な場合を除いて、ルートユーザーを利用しない
2. ルートユーザーなどの特権ユーザーに対して、MFA を有効化する。
3. 利用者ごとにIAMユーザーを作成する
4. 組織利用の場合は、役割ごとのIAMグループを作成してグループで管理するのを基本とする
5. 最小限の権限設定と不要な認証情報は削除を心がける
6. ユーザーのために強度の高いパスワードポリシーを設定する。
7. EC2インスタンスで作動するアプリケーションなどプログラムから利用する場合はなるべくロールを使用する。
8. モバイルやアプリケーションも含め、一時利用にはSTSなどで最小限の利用許可を与える
9. AWSアカウントのアクティビティを常に監視する

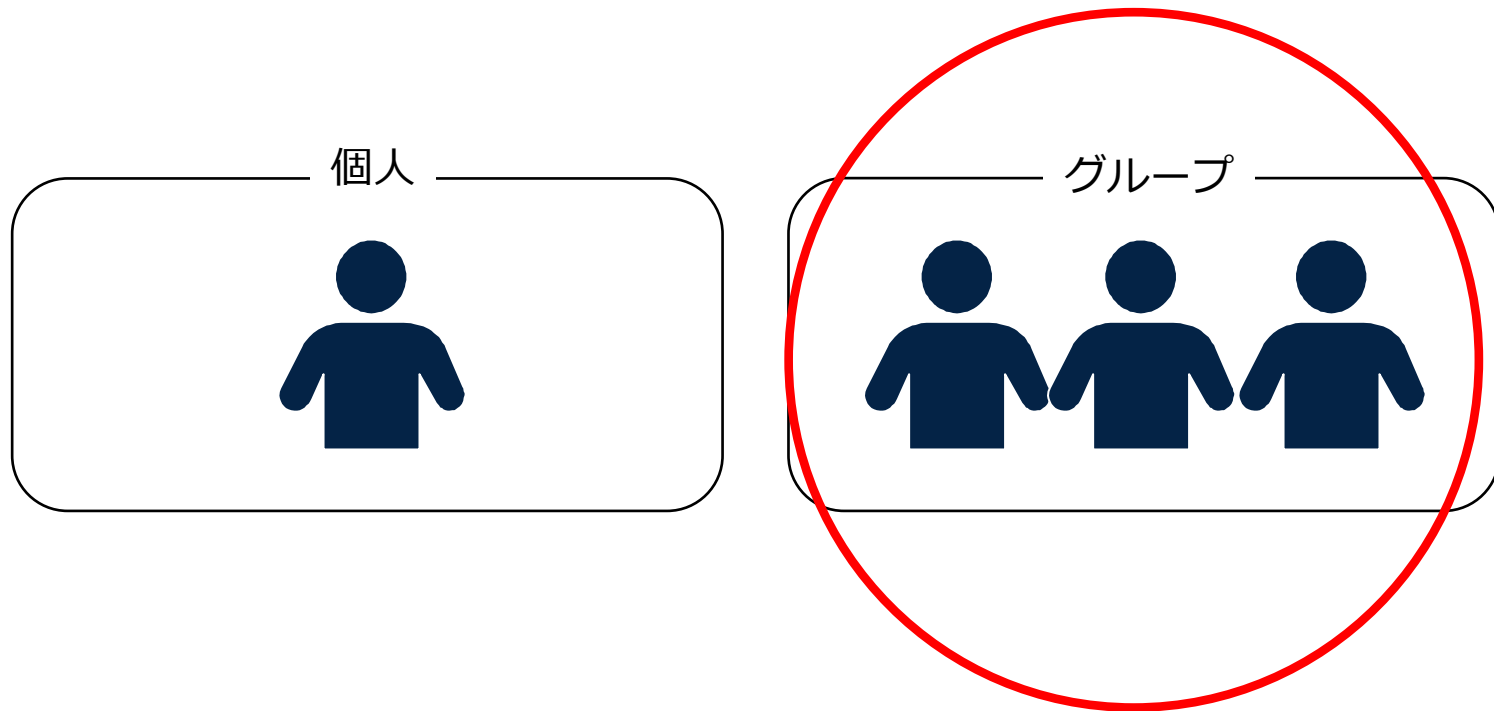
①IAMユーザー or IAMグループ

少数利用はIAMユーザーを組織利用はIAMグループを設定する



①IAMユーザー or IAMグループ

少数利用がずっと継続する場合を除いて、少数利用も含めて最初からIAMグループで設定する方が良い



②グループ設計

組織別または個人単位にAWS利用者とその役割別の利用範囲を整理して、グループ設計を実施する

AWS利用者と役割の洗い出し

AWS利用者の特定

利用者の役割と利用範囲を整理

利用グループへと集約

同じ役割や利用範囲を1つのグループとしてまとめる

グループ別の名称と最小限利用範囲を確定する

IAMグループへの ポリシー適用

このハンズオンで実施する内容

1. 自社組織に必要な権限を設計する
2. 自分で独自のポリシーを作成する
3. グループを作成しポリシーを適用する

ケーススタディ：自社組織に必要な権限設計

今回のIAM設計を行う組織は以下の通りです。どのような権限を設定すべきか考えてみましょう

IT管理者

IT管理者としてルートユーザーも保持し、権限設定などの責任を負っている

運用管理者

運用管理全般を担っているスタッフで、様々なモニタリングと障害対応などで直接アプリに触れることもある

アプリ開発者

主だったAWSサービスを利用してサービス開発を行っている。

ケーススタディ：自社組織に必要な権限設計

今回のIAM設計を行う組織は以下の通りです。どのような権限を設定すべきか考えてみましょう

IT管理者

フルアクセスの管理者
権限の付与（MFAが必須）

運用管理者

運用ツール全般と開発
環境へのアクセスも付
与して、DevOpsに参加
できるようにする

アプリ開発者

担当しているアプリの
開発範囲でのみアクセ
ス権限を付与する

ケーススタディ：自社組織に必要な権限設計

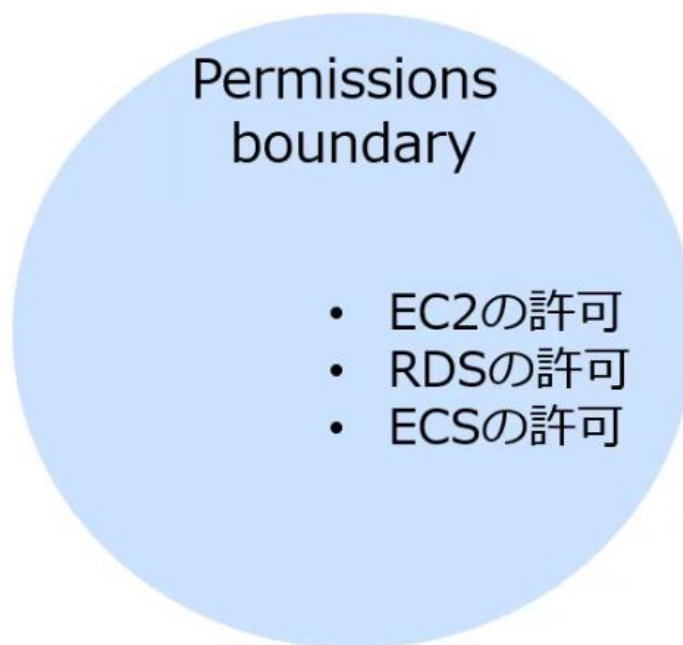
今回のIAM設計を行う組織は以下の通りです。どのような権限を設定すべきか考えてみましょう

IT管理者	運用管理者	アプリ開発者
フルアクセスの管理者 権限の付与（MFAが必須） 管理ポリシー Administrator	運用ツール全般と開発 環境へのアクセスも付 与して、DevOpsに参 加できるようにする • ELB／EC2／RDB／ S3／Auto-Scaling ／ VPC • Config／CloudTrail ／CloudWatch	担当しているアプリの 開発範囲でのみアクセ ス権限を付与する • ELB／EC2／RDB／ S3／Auto-Scaling／ VPC

アクセス権限の境界設定

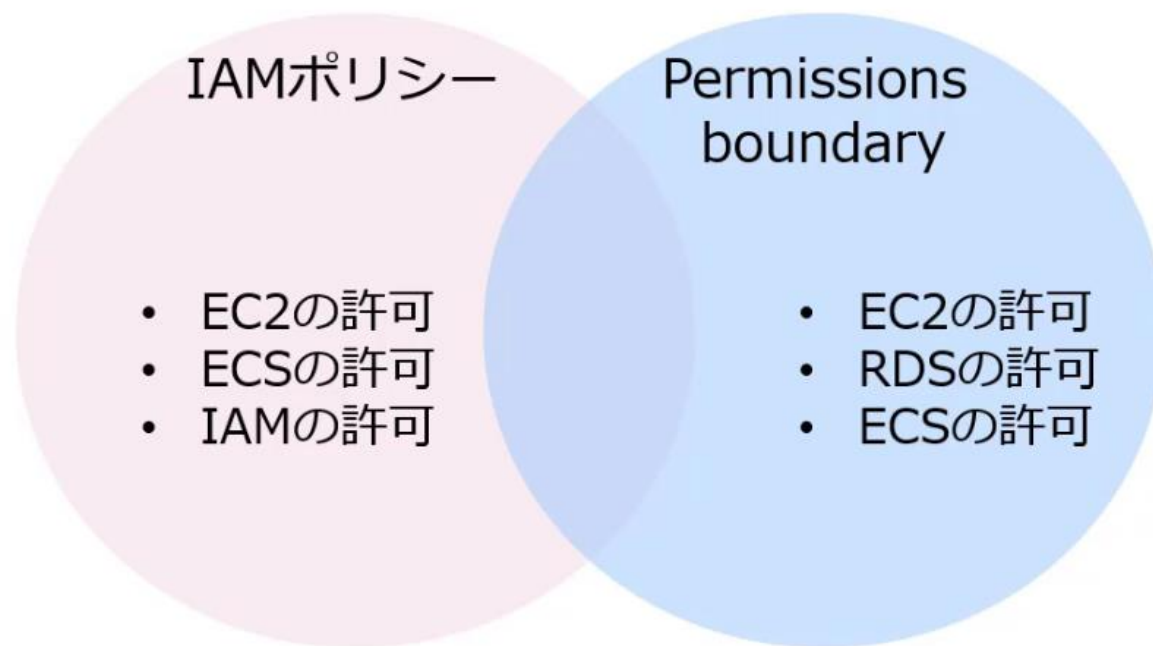
Permissions boundary

IAMユーザーに対して権限境界（Permissions boundary）を設定して、付与可能な権限範囲をあらかじめ制限できる。



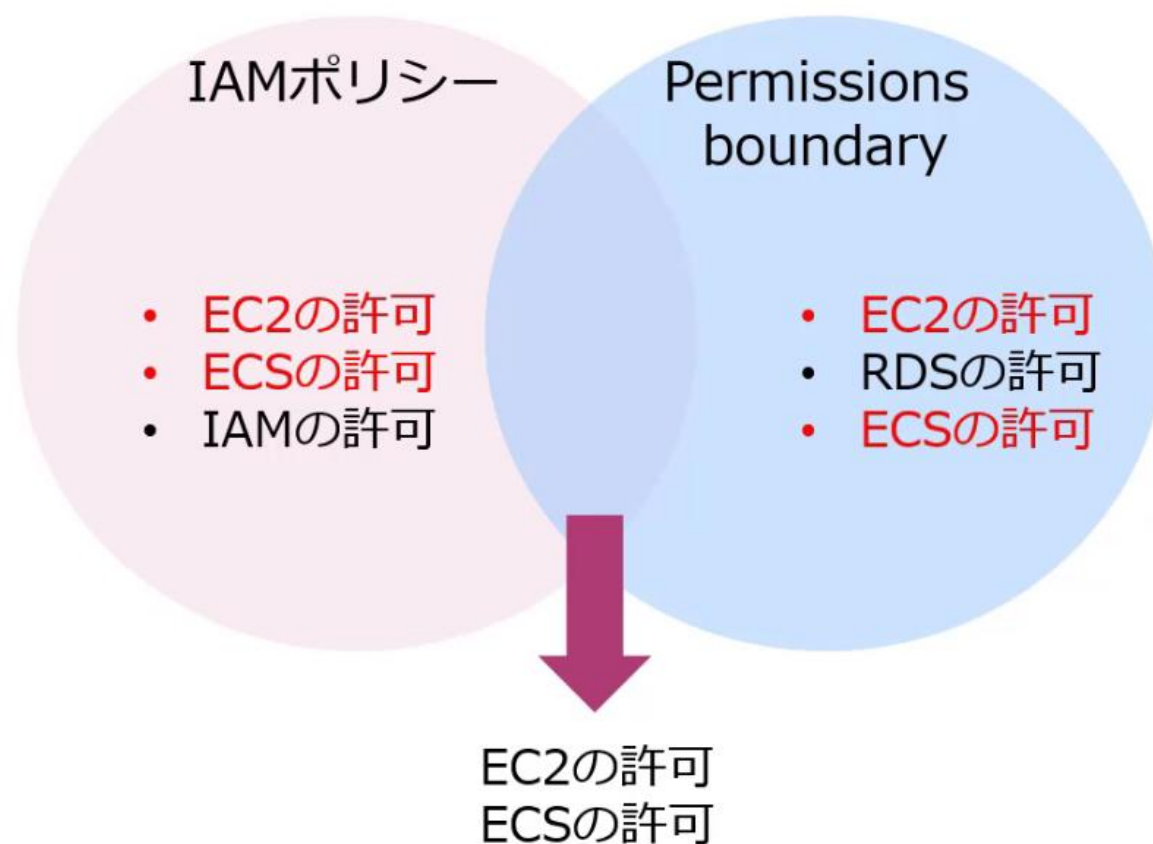
Permissions boundary

IAMユーザーに対して権限境界（Permissions boundary）を設定して、付与可能な権限範囲をあらかじめ制限できる。



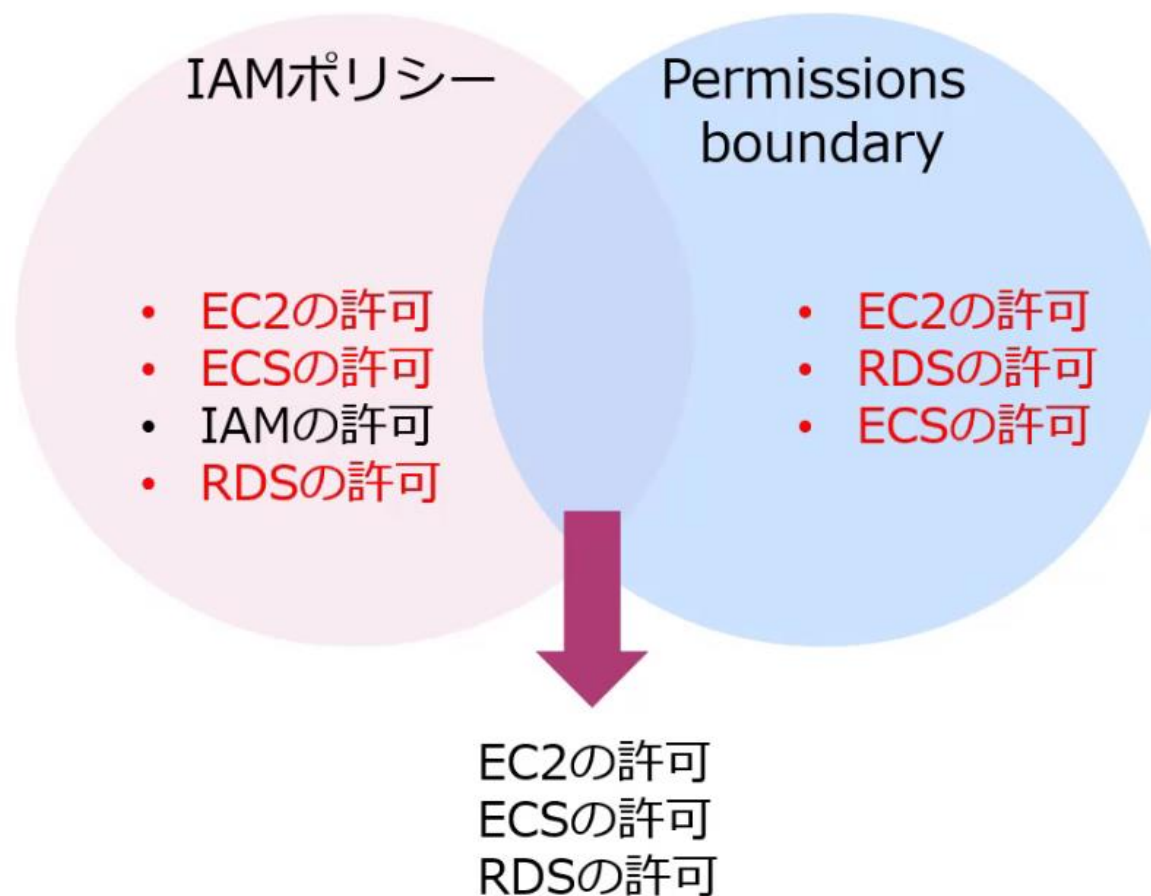
Permissions boundary

IAMユーザーに対して権限境界（Permissions boundary）を設定して、付与可能な権限範囲をあらかじめ制限できる。



Permissions boundary

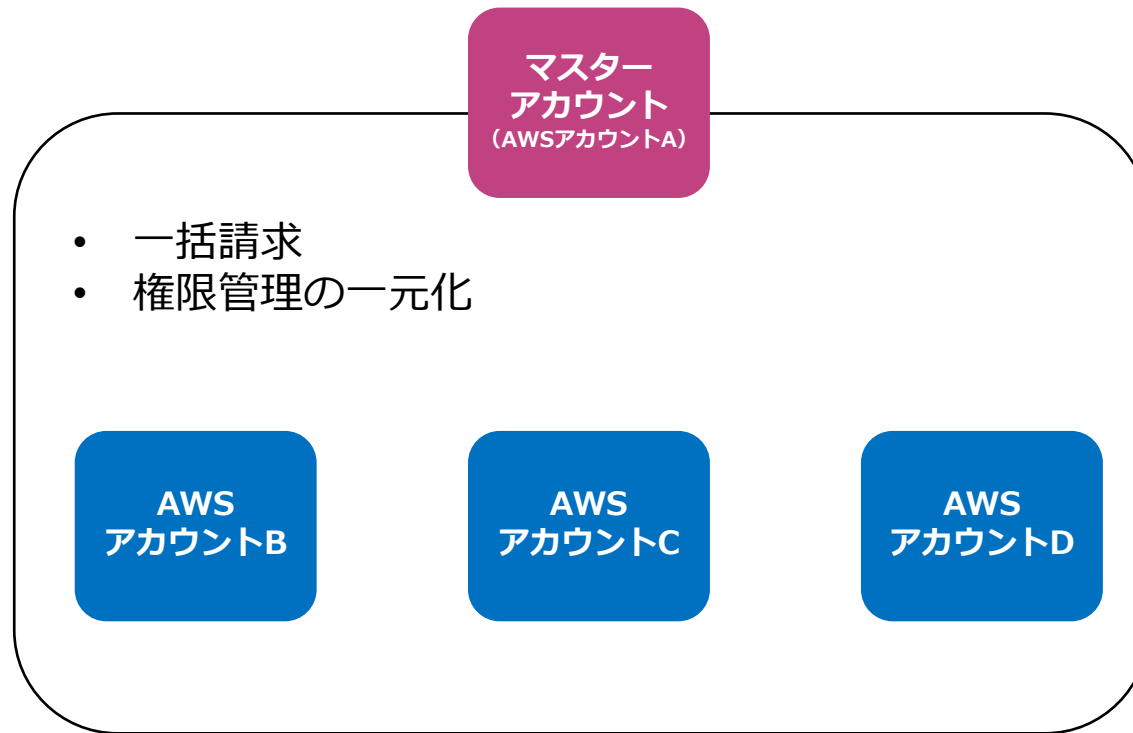
IAMユーザーに対して権限境界（Permissions boundary）を設定して、付与可能な権限範囲をあらかじめ制限できる。



AWS Organizations の概要

AWS Organizationsとは何か？

複数のAWSアカウントを利用している場合に、統合管理を実施することができる



AWS Organizations

AWS OrganizationsはIAMのアクセス管理を大きな組織でも楽に実施できるようにするマネージド型サービス

複数アカウントの 一元管理

AWSアカウントをグループ化してポリシーを適用して一元的に管理する

新規アカウント 作成管理

コンソール／SDK／CLIでAWSアカウントを新規作成して、作成内容をログ管理できる

一括請求

複数AWSアカウントの請求を一括化する

Organizationsの選択

支払一括代行とアカウントの全体管理の2つの方式を選択する

Consolidated Billing Only

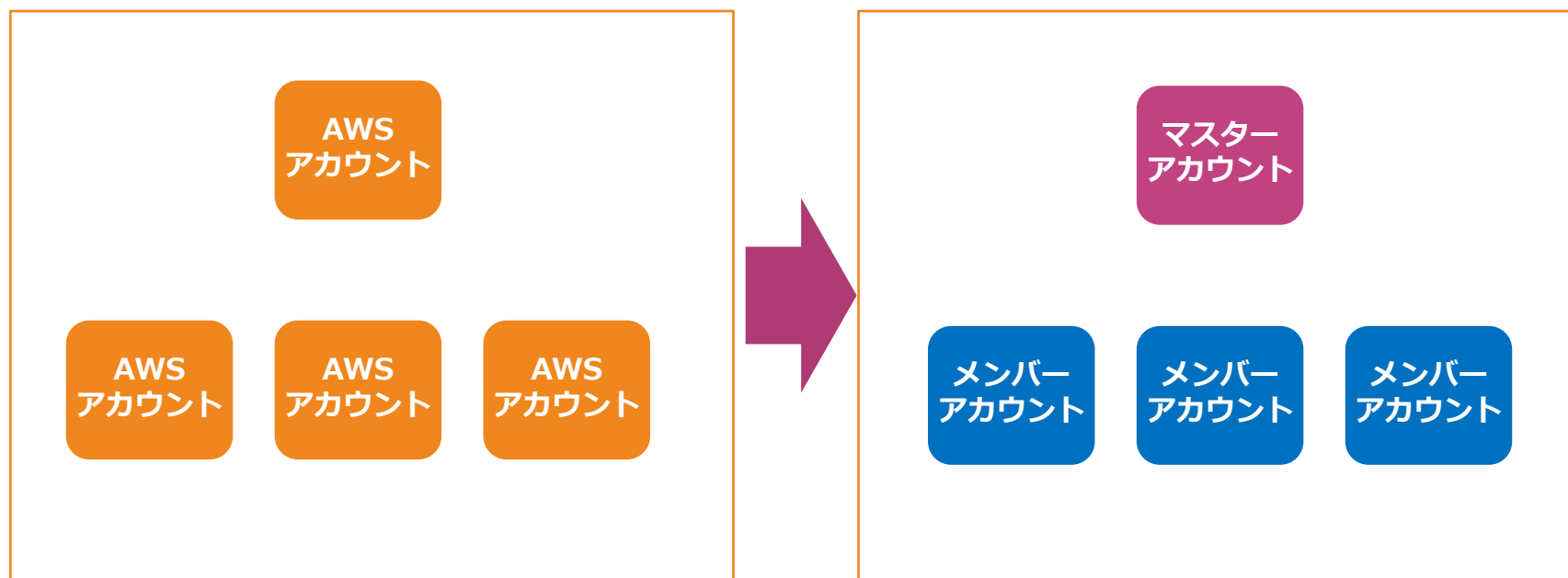
- ✓ 支払一括代行のみを実施する場合に選択
- ✓ ボリュームディスカウントを統合できるため、コストメリットが発生する。

All Feature

- ✓ 支払一括代行も含めて、企業内の複数アカウントを統制したい場合に選択

アカウントの設定

AWSアカウントの中からマスターアカウントを選定する

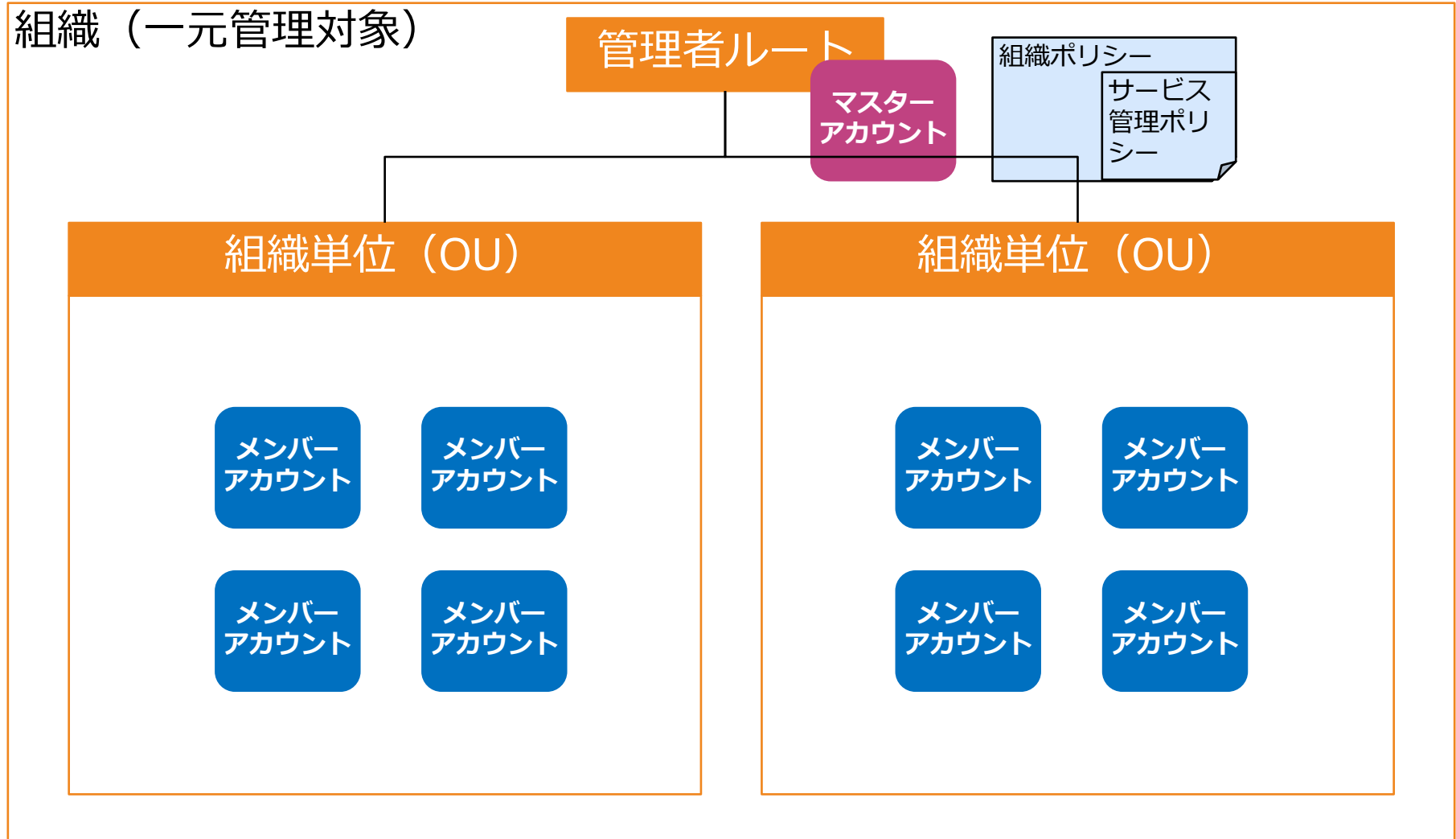


- ✓ メンバーアカウントはマスターアカウントから招待を承認するとメンバーアカウントとして登録される。
- ✓ メンバーアカウントから削除する際は独立したアカウントとして請求処理など設定する必要がありましたが、コンソールから容易に削除できるようになりました。

AWS Organizations

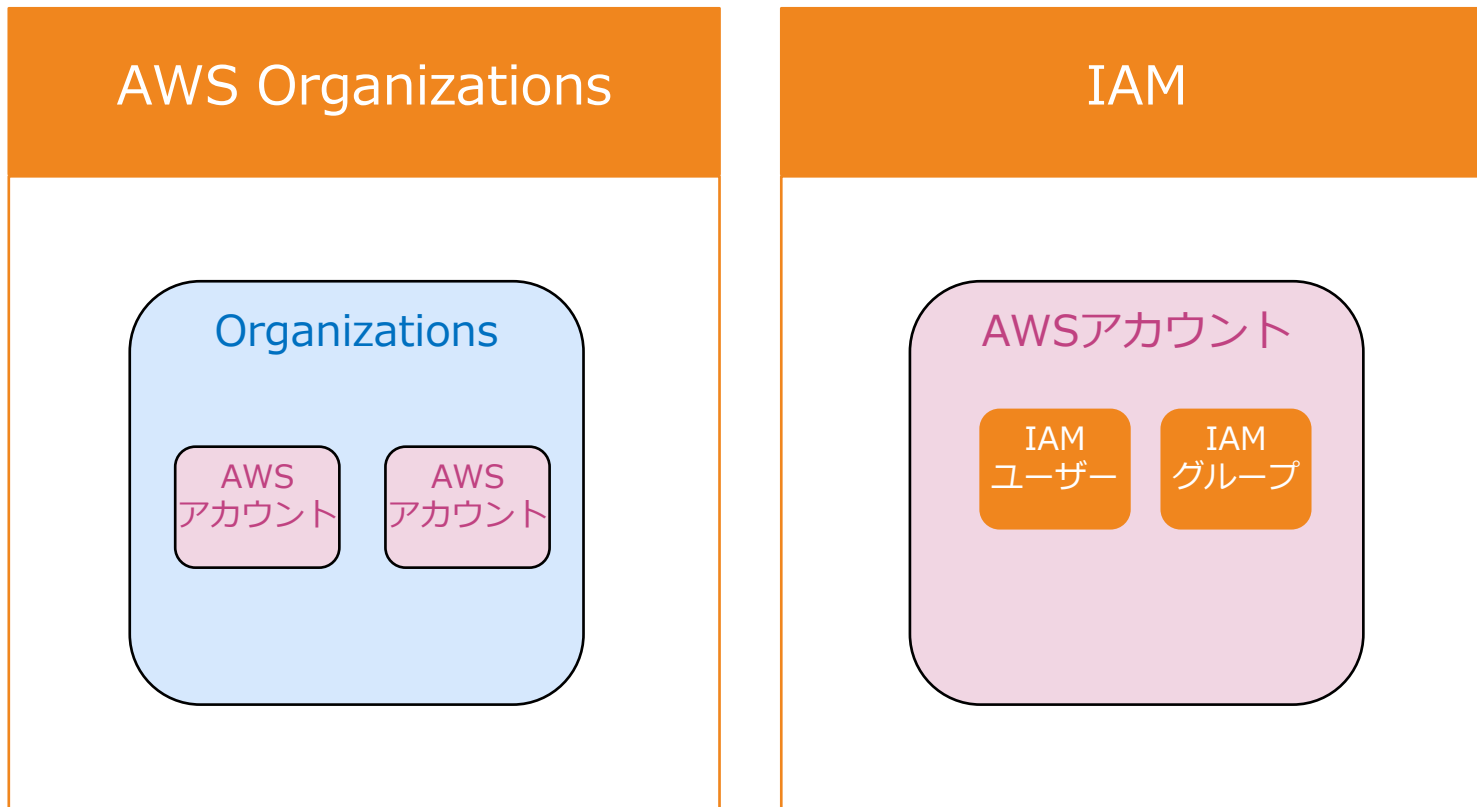
組織という単位を構成して、マスターアカウントがメンバーアカウントを管理するという仕組み

組織（一元管理対象）



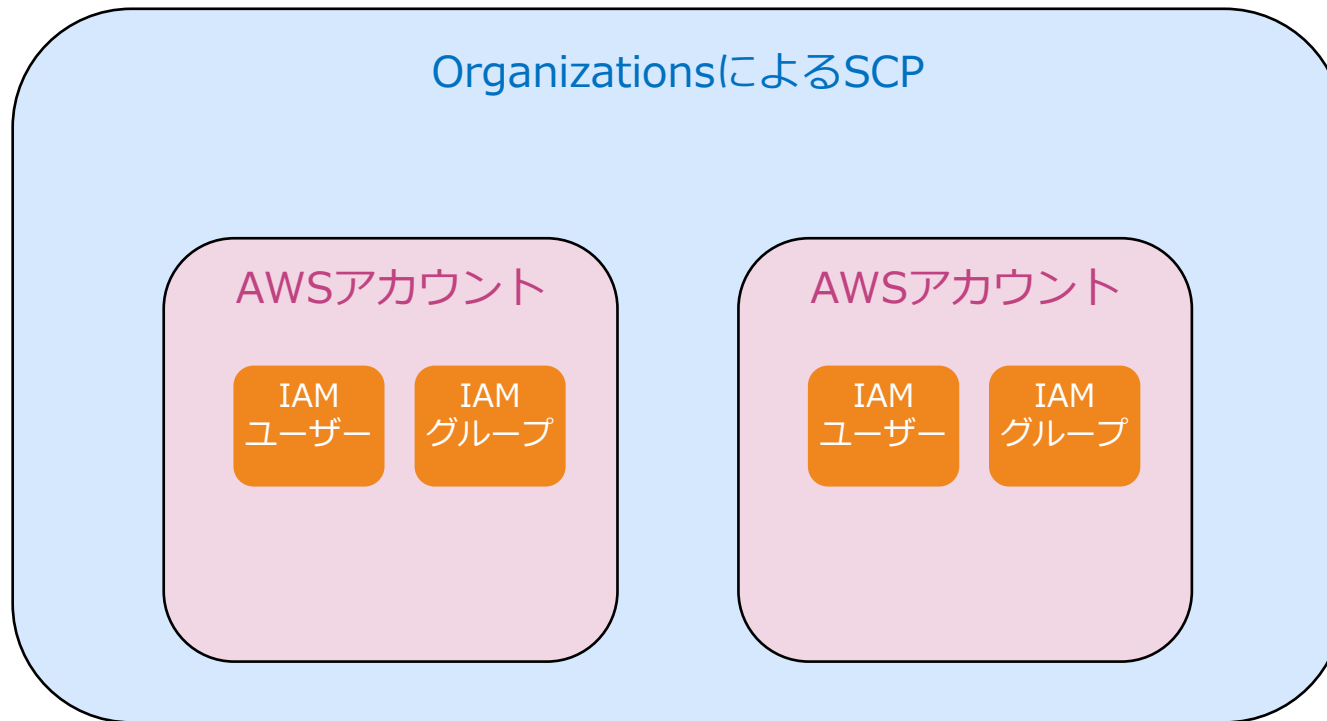
IAMとAWS Organizations

IAMはAWSアカウント内のユーザー管理を実施。
Organizationsは複数のAWSアカウント自体の管理を実施。



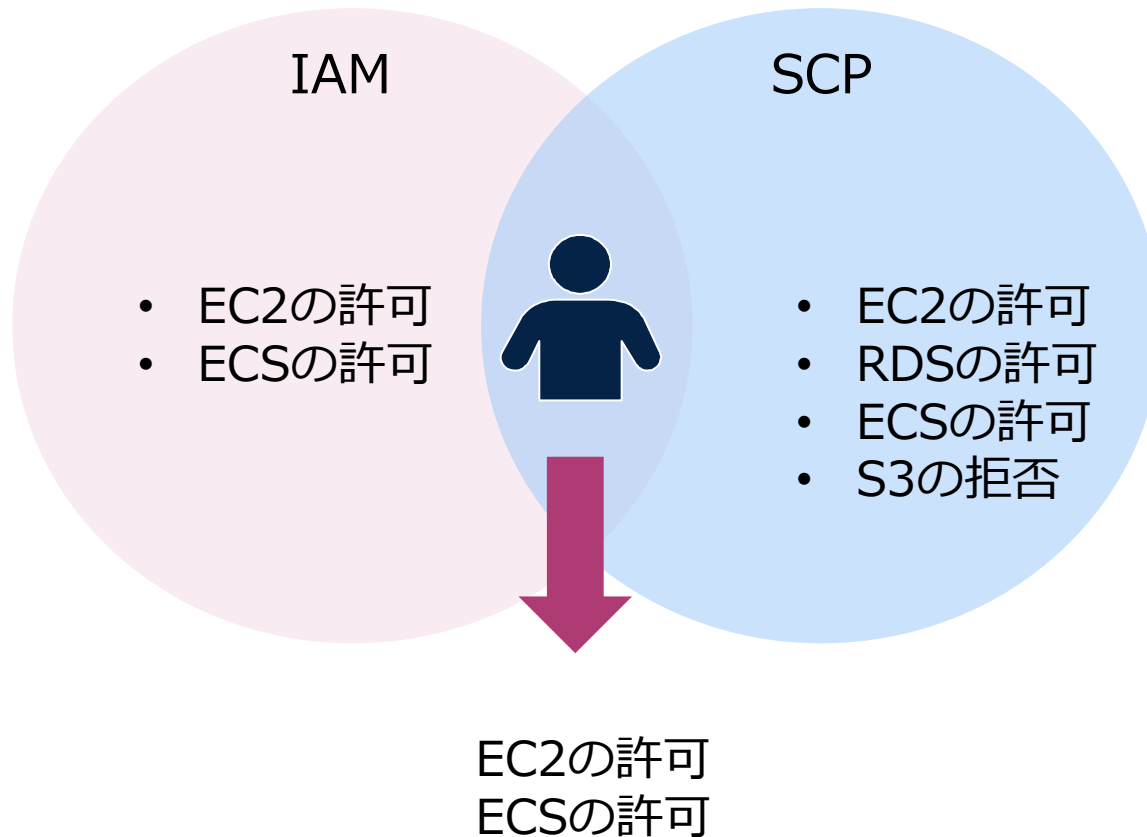
IAMポリシーとSCP

IAMはAWSアカウント内のユーザーへの許可権限を付与し、
SCPはAWSアカウント全体の権限付与が可能な範囲を決める。



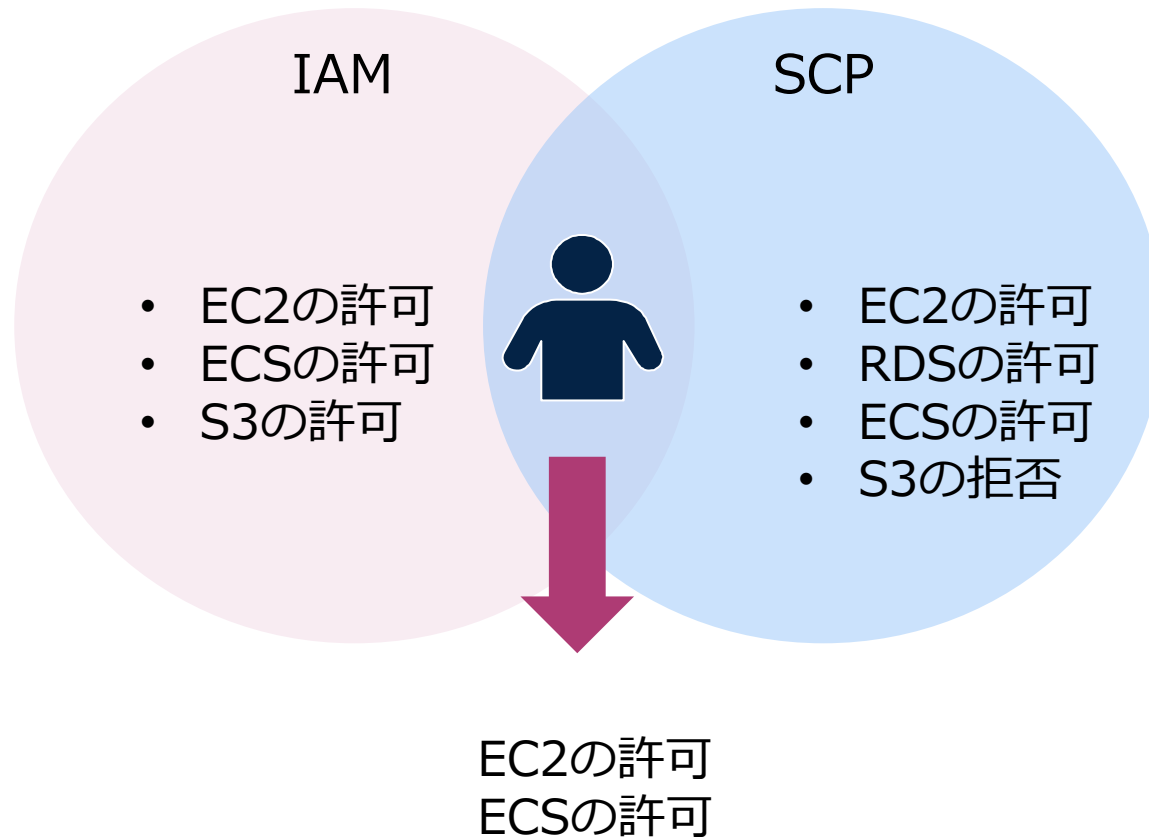
SCP (Service Control Policy)

SCPというポリシーを利用して、OU内のメンバーに対して権限境界を設定することができる。



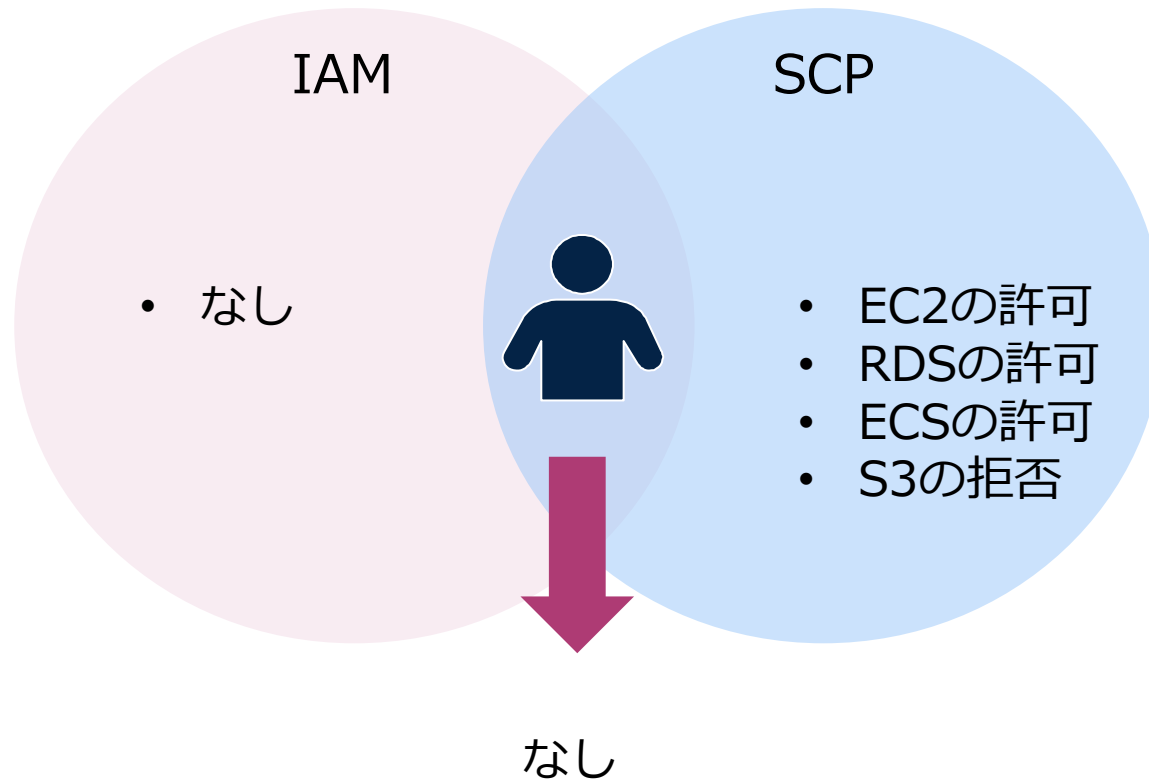
SCP (Service Control Policy)

SCPというポリシーを利用して、OU内のメンバーに対して権限境界を設定することができる。



SCP (Service Control Policy)

SCPというポリシーを利用して、OU内のメンバーに対して権限境界を設定することができる。



SCPの例

SCPは許可する範囲を指定するホワイトリスト形式と拒否する範囲を指定するブラックリスト形式が存在する。

ホワイトリスト形式

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAllOutsideOU",
      "Effect": "Allow",
      "NotAction": [
        "ec2:*",
        "iam:*",
        "s3:*",
        "aws-marketplace:*",
        "aws-portal:*"
      ],
    }
  ]
}
```

ブラックリスト形式

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAllOutsideOU",
      "Effect": "Deny",
      "NotAction": [
        "ec2:*",
        "iam:*",
        "s3:*",
        "aws-marketplace:*",
        "aws-portal:*"
      ],
    }
  ]
}
```

SCPの適用範囲

ホワइटリスト形式に加えて拒否設定が追加されると、明示的か拒否設定が優先される。

ホワइटリスト形式

```
{  
  "Version": "2012-10-17",  
  "Statement": {  
    "Effect": "Allow",  
    "Action": "*",  
    "Resource": "*"   
  }  
}
```

ブラックリスト形式

```
{  
  "Version": "2012-10-17",  
  "Statement": {  
    "Effect": "Deny",  
    "Action": "ec2:*",  
    "Resource": "*"   
  }  
}
```

SCPの適用範囲

ホワइटリスト形式に加えて拒否設定が追加されると、明示的か拒否設定が優先される。

ホワइटリスト形式

```
{  
  "Version": "2012-10-17",  
  "Statement": {  
    "Effect": "Allow",  
    "Action": "*",  
    "Resource": "*"   
  }  
}
```

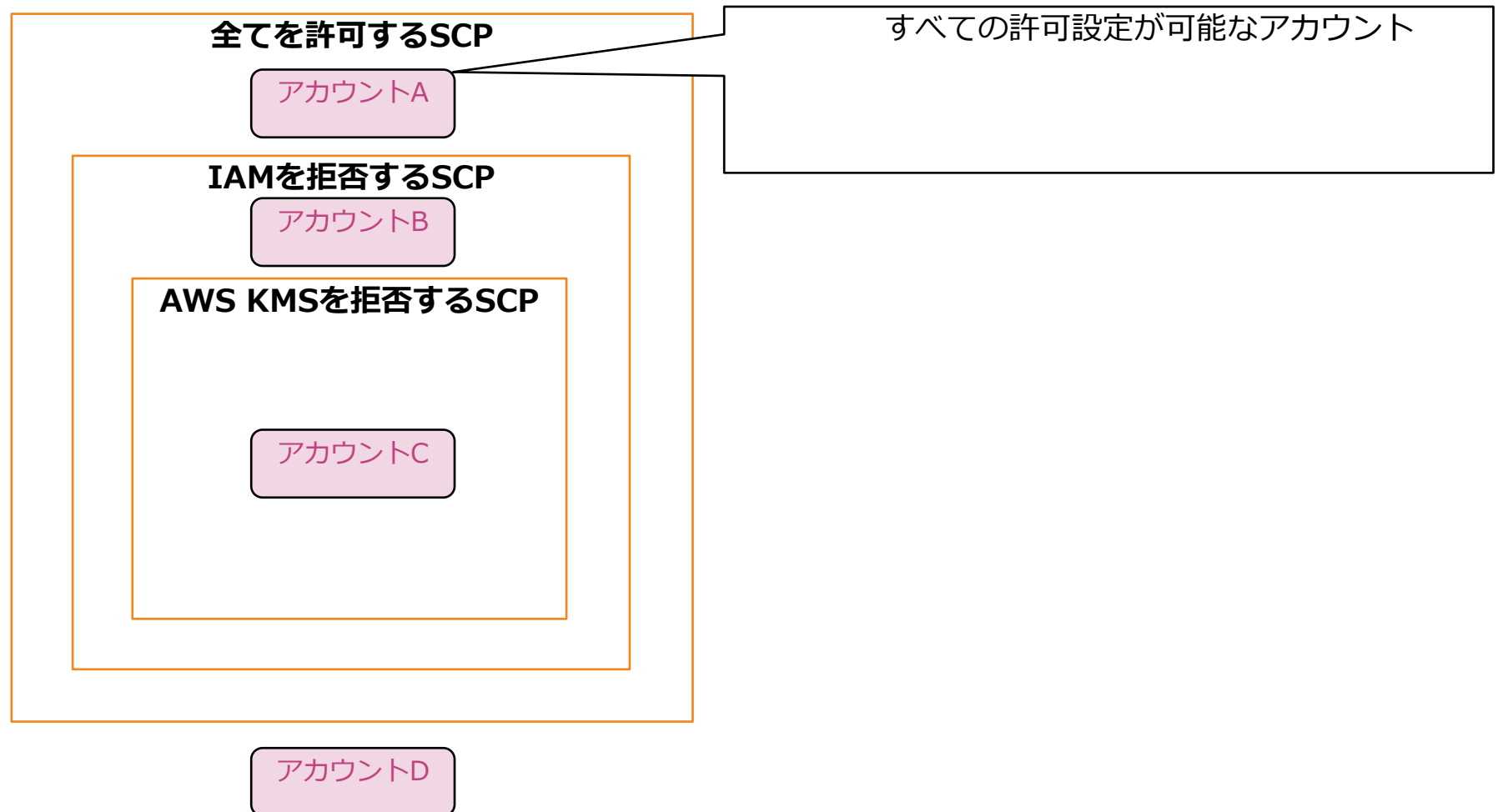
ブラックリスト形式

```
{  
  "Version": "2012-10-17",  
  "Statement": {  
    "Effect": "Deny",  
    "Action": "ec2:*",  
    "Resource": "*"   
  }  
}
```

EC2以外の権限設定が可能なアカウントとなる。

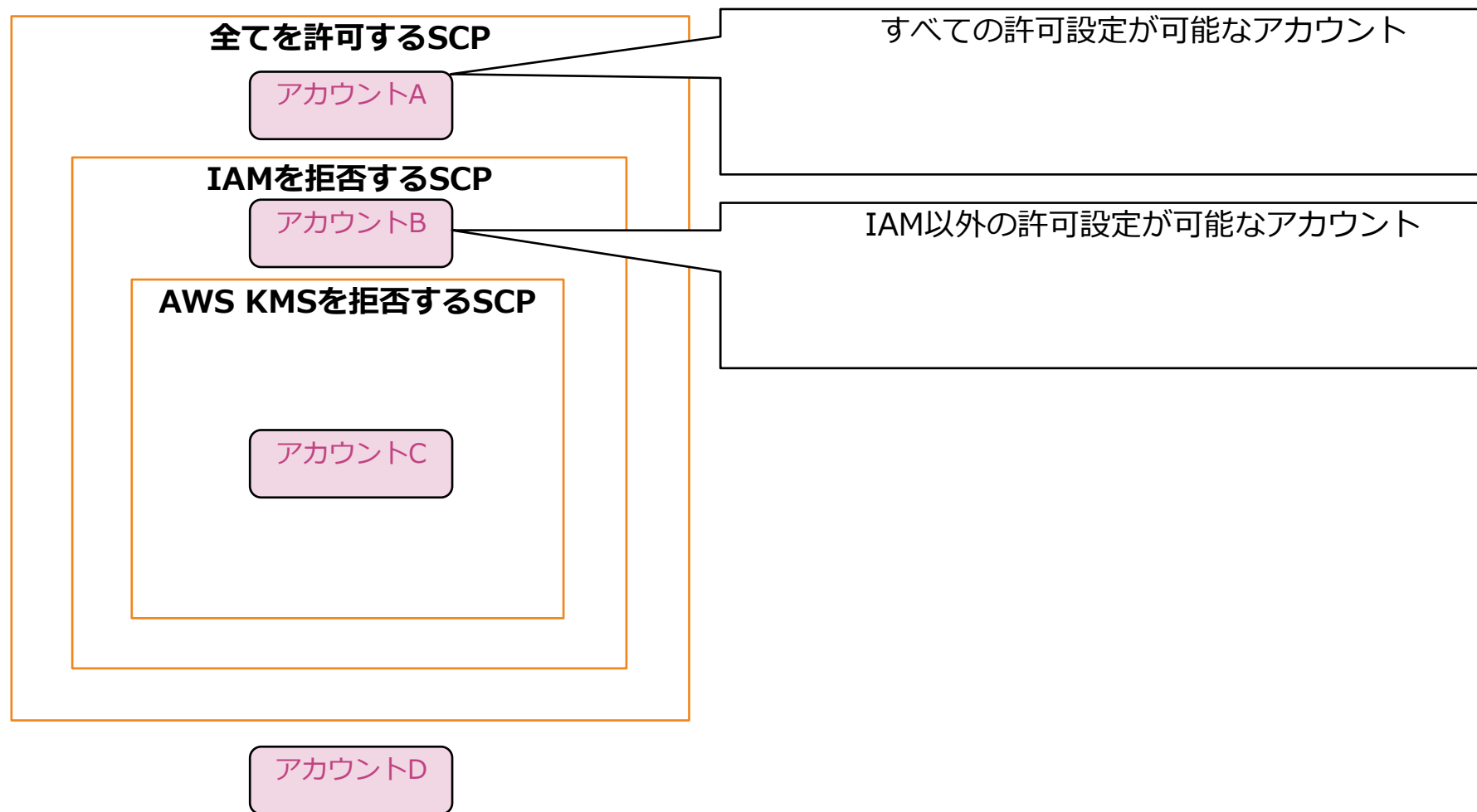
SCPの適用範囲

SCPが複数付与されている場合のアカウント別の許可可能な範囲は以下の通り



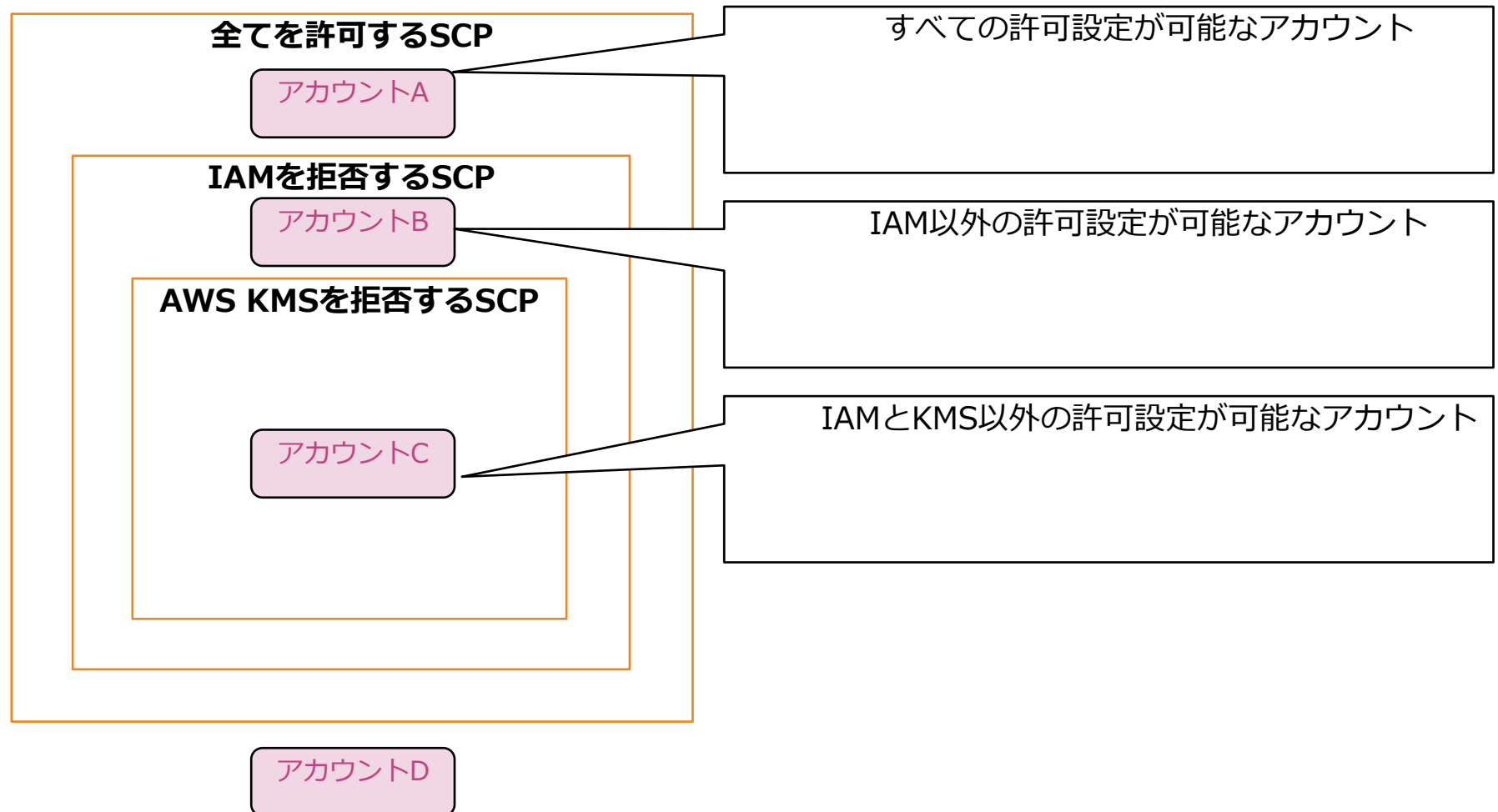
SCPの適用範囲

SCPが複数付与されている場合のアカウント別の許可可能な範囲は以下の通り



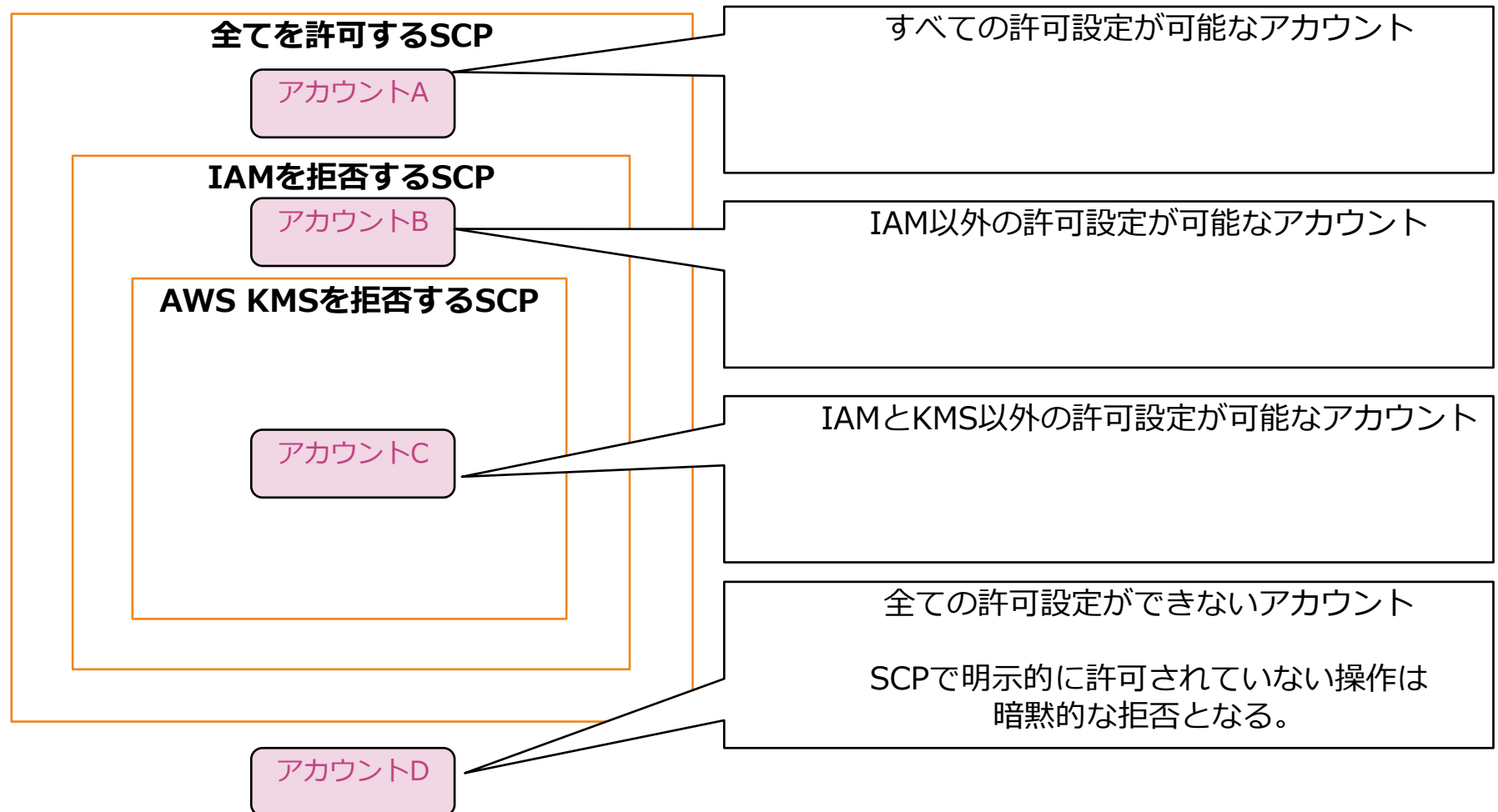
SCPの適用範囲

SCPが複数付与されている場合のアカウント別の許可可能な範囲は以下の通り



SCPの適用範囲

SCPが複数付与されている場合のアカウント別の許可可能な範囲は以下の通り



リソースのシェア

AWS Organizationsのメンバーアカウント間でリソースを共有できる。

AWS Resource Access Manager (RAM) との連携

- ✓ 異なるAWSアカウントとリソースを共有する仕組み。
- ✓ AWS Organizationsの組織内のアカウントとの共有や組織外のアカウントとの共有も可能
- ✓ 1つのVPCを共有して、複数アカウントのリソースを展開することができる。
- ✓ リソース間の通信が容易になる。

リザーブドインスタンスの共有

- ✓ AWS Organizationsの機能
- ✓ アカウントでリザーブドインスタンスの共有がオンになっている
- ✓ AWS Organizationsを利用した一括請求でリザーブドインスタンスが共有される。